UNIVERSIDADE FEDERAL DO ESTADO DO RIO DE JANEIRO
CENTRO DE CIÊNCIAS EXATAS E TECNOLOGIA - CCET
PROGRAMA DE PÓS-GRADUAÇÃO EM INFORMÁTICA - PPGI

INVESTIGANDO ONTOLOGIAS DE SEGURANÇA EM SISTEMAS DE INFORMAÇÃO

Roberto Monteiro Dias

Orientador
Sean Wolfgand Matsui Siqueira

RIO DE JANEIRO, RJ - BRASIL
MAIO DE 2025

Dedico este trabalho aos meus pais, irmãos e amigos, pelo apoio e orações que tornaram possível esta conquista.

Agradecimentos

Gostaria de expressar meus sinceros agradecimentos aos professores Ana Cristina Bicharra Garcia, Paulo Sergio Medeiros dos Santos e Sean Wolfgand Matsui Siqueira pela valiosa orientação, pelo generoso compartilhamento de conhecimentos e pelas oportunidades de crescimento profissional e pessoal oferecidas ao longo do doutorado.

Agradeço também a todos os servidores e colaboradores do Programa de Pós-Graduação em Informática da UNIRIO (PPGI-UNIRIO), cuja dedicação e apoio foram fundamentais para a realização desta dissertação.

DIAS, Roberto Monteiro. **Investigando Ontologias de Segurança em Sistemas de Informação**. UNIRIO, 2025. 80 páginas. Monografia do Exame de Qualificação de Doutorado. Programa de Pós-Graduação em Informática, UNIRIO.

RESUMO

A crescente interconexão de sistemas — como Sistemas de Sistemas (SoS), Sistemas Ciberfísicos (CPS) e Sistemas Inteligentes —, impulsionadas pelo uso de APIs, têm proporcionado ganhos expressivos de eficiência. No entanto, esse avanço também tem ampliado as vulnerabilidades de segurança. Para garantir uma comunicação segura, que observe os princípios de *confiabilidade*, *integridade* e *disponibilidade*, propõe-se o uso de ontologias como uma solução estratégica. Ontologias possibilitam a integração de dados heterogêneos e fortalecem a governança em ambientes complexos e dinâmicos. Este estudo realiza uma Revisão Sistemática da Literatura (RSL) com o objetivo de mapear os métodos, técnicas e ferramentas empregados no uso de ontologias voltadas à segurança em Sistemas de Informação, considerando as dimensões de Processos, Pessoas e Tecnologias. Como principal contribuição, será desenvolvida uma taxonomia multidimensional, estruturada com base nessas três dimensões e suas respectivas subcategorias, fundamentada nas questões de pesquisa delineadas ao longo deste estudo.

Palavras-chave: Integração de Sistemas; Ontologias; Revisão Sistemática; Segurança da Informação; Taxonomia.

.

DIAS, Roberto Monteiro. **Investigating Security Ontologies for Information Systems**. UNIRIO, 2025. 80 pages. Doctoral Qualifying Exam Thesis. Graduate Program in Informatics, UNIRIO.

ABSTRACT

The increasing interconnection of systems—such as Systems of Systems (SoS), Cyber-Physical Systems (CPS), and Intelligent Systems—driven by the use of APIs, have brought significant efficiency gains. However, this advancement has also expanded security vulnerabilities. To ensure secure communication that upholds the principles of *reliability*, *integrity*, and *availability*, the use of ontologies is proposed as a strategic solution. Ontologies enable the integration of heterogeneous data and strengthen governance in complex and dynamic environments. This study conducts a Systematic Literature Review (SLR) aimed at mapping the methods, techniques, and tools employed in the use of ontologies focused on security in Information Systems, considering the dimensions of Processes, People, and Technologies. As its main contribution, a multidimensional taxonomy will be developed, structured based on these three dimensions and their respective subcategories, grounded on the research questions outlined throughout this study.

Keywords: Information Security; Ontologies; Systematic Review; Systems Integration; Taxonomy.

.

Sumário

1 Introdução **1**
1.1 Contexto 1
1.2 Motivação 3
1.3 Exemplo Prático, Hipotético e Fictício 4
1.4 Problema 7
1.5 Objetivo 8
1.6 Metodologia 9
1.7 Organização 10

2 Fundamentação Teórica **12**
2.1 Ontologias 12
2.1.1 Ontologias de Segurança 13
2.2 Segurança da Informação 14
2.3 Taxonomia 15
2.4 Etapas do Desenvolvimento da Taxonomia 16
2.5 Considerações Finais 17

3 Trabalhos Relacionados **18**
3.1 Introdução 18
3.2 Contexto 18
3.3 Considerações Finais 19

4 Revisão Sistemática da Literatura **21**
4.1 Introdução 21
4.2 Protocolo e Execução 22
4.2.1 Planejamento 22
4.2.1.1 Questão de Pesquisa: 22
4.2.1.2 **Fontes de Busca:** 23
4.2.1.3 **Definição dos Termos de Pesquisa:** 23
4.2.1.4 **Critérios de Seleção dos Estudos:** 23
4.2.2 Execução 24

4.2.2.1 Processo de Seleção dos Estudos 24
4.2.3 Levantamento de Dados 25
4.3 Apresentação dos resultados 25
4.3.1 Dados demográficos 26
4.3.2 Limitações 28
4.4 Análise dos Resultados 28
4.5 Considerações Finais 52

5 Taxonomia 54
5.1 Introdução 54
5.2 Processo de contrução da taxonomia 54
5.2.1 Etapa 1 - Determinar o domínio e o escopo da taxonomia 55
5.2.2 Etapa 2 - Definir o processo de aquisição de conhecimento para a construção da taxonomia 56
5.2.3 Etapa 3 - Analisar e organizar o conhecimento para a contrução da taxonomia 56
5.2.4 Etapa 4 - Estruturar e modelar a taxonomia 57
5.2.4.1 Taxonomia elaborada a partir da análise sistemática dos estudos selecionados, com o objetivo de responder à Questão de Competência 1. 57
5.2.4.2 Taxonomia elaborada a partir da análise sistemática dos estudos selecionados, com o objetivo de responder à Questão de Competência 2. 59
5.2.4.3 Taxonomia elaborada a partir da análise sistemática dos estudos selecionados, com o objetivo de responder à Questão de Competência 2. 60
5.3 Considerações Finais 62

6 Conclusão 63
6.1 Epílogo 63
6.2 Contribuições 65
6.3 Trabalhos Futuros 66

Referências 71

Lista de Figuras

Figura 1 À esquerda, as instalações das Usinas Termonucleares Angra 1 e Angra 2; à direita, o complexo do Centro Nuclear Almirante Álvaro Alberto (CNAAA), composto pelas usinas Angra 1, Angra 2 e Angra 3 (em fase de construção). 4
Figura 2 Simulação hipotética de um ataque hacker à Divisão de Serviços da Hora Legal Brasileira do Observatório Nacional (ON). Fonte: Divisão do Serviço da Hora do Observatório Nacional (DSHO/ON). . . . 6
Figura 3 Salas de controle das usinas nucleares Angra 1 (à esquerda), a primeira planta nuclear do Brasil, e Angra 2 (à direita). 8
Figura 4 Metodologia aplicada nesta pesquisa. 9
Figura 5 Exemplo de ontologia de segurança. 14
Figura 6 Etapas do Desenvolvimento da Taxonomia. 16
Figura 7 Processo de seleção de estudos. 24
Figura 8 Quantidade de estudos publicados por ano. 26
Figura 9 Quantidade de estudos publicados por país. 26
Figura 10 Distribuição percentual dos estudos por subcategoria. 35
Figura 11 Distribuição percentual dos estudos por subcategorias nas dimensões fundamentais de Sistemas de Informação (SI). 42
Figura 12 Distribuição percentual dos estudos nas dimensões de SI 52
Figura 13 Taxonomia multidimensional organizada nas três dimensões de SI. . 61

Lista de Tabelas

Tabela 1 Subquestões de Pesquisa 8
Tabela 2 Critérios de PIO 22
Tabela 3 Subquestões de Pesquisa 22
Tabela 4 Critérios de Seleção 23
Tabela 5 Dados extraídos dos estudos selecionados 27
Tabela 6 Estudos relacionados ao uso de ontologias em Segurança da Informação por dimensão e abordagem. 30
Tabela 7 Estudos na dimensão **Tecnologias** – categorizados por tipo de abordagem – relacionados às respostas da Sub-Q1. 34
Tabela 8 Distribuição dos estudos pelas dimensões em SI e subcategorias identificadas nesta RSL. 35
Tabela 9 Estudos na dimensão **Pessoas** — Avaliações de Usabilidade, Qualitativa e Profissional relacionadas às respostas da Sub-Q2. 37
Tabela 10 Avaliações dos estudos segundo a dimensão **Processos**, por tipo de avaliação 40
Tabela 11 Avaliações dos estudos segundo a dimensão **Tecnologias**, por tipo de avaliação 41
Tabela 12 Distribuição dos estudos nas dimensões fundamentais em Sistemas de Informação (SI) e pelas subcategorias identificadas nos estudos analisados (corrigida). 42
Tabela 13 Estudos relacionados às respostas da Sub-Q3, organizados por dimensão (**Pessoas** e **Processos**). 46
Tabela 14 Estudos na dimensão **Tecnologias** — Aspectos Técnicos de Implementação e Normas e Integração de Ontologias relacionados às respostas da Sub-Q3. 51
Tabela 15 Distribuição dos estudos nas dimensões fundamentais em SI e pelas subcategorias identificadas nos estudos analisados 52
Tabela 16 Template de Especificação da Taxonomia 55

1. Introdução

Este capítulo tem como objetivo apresentar o contexto, a motivação, a caracterização do problema, os objetivos, as questões de pesquisa e a metodologia científica utilizada nesta monografia. Ao final, apresenta-se a organização do documento e uma breve descrição dos capítulos que o compõem.

1.1 Contexto

As transformações significativas no cenário econômico e social têm tornado o controle da Segurança da Informação em SI cada vez mais complexo. A intensificação da integração de sistemas, impulsionada pelo uso de *Interfaces de Programação de Aplicações* (APIs), evidencia a interoperação entre diferentes sistemas complexos, como os *Sistemas de Sistemas* (*Systems-of-Systems* – SoS), os *Sistemas Ciberfísicos* (*Cyber-Physical Systems* – CPS) e os *Sistemas Inteligentes* (*Intelligent Systems*) (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022).

Os sistemas, enquanto categorias de sistemas complexos, têm como objetivo primordial a integração de tecnologias e conhecimentos heterogêneos para viabilizar autonomia, confiabilidade, organização e controle eficazes, minimizando ou eliminando a necessidade de intervenção humana direta(MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018a; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022). Suas aplicações abrangem diversos domínios, incluindo Internet das Coisas (IoT), análise de Big Data, tecnologias inteligentes e computação em nuvem (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018a; INO-

CêNCIO et al., 2019; LADEGOURDIE; KUA, 2022). No âmbito da Indústria 4.0, tais sistemas assumem papel estratégico na modernização e automação de setores críticos, tais como manufatura avançada, medicina de precisão, infraestrutura urbana, veículos autônomos, dispositivos vestíveis, sistemas móveis, defesa e previsão meteorológica (LADEGOURDIE; KUA, 2022).

Em ambientes sociotécnicos — que combinam aspectos sociais e tecnológicos — e que apresentam elevada dinamicidade, os sistemas complexos distribuídos no contexto dos SI desempenham papel fundamental na prestação de serviços críticos em diversas áreas, tais como: controle de tráfego, distribuição de energia, gerenciamento de edificações, integração de modais de transporte, operação de veículos autônomos, saúde, segurança pública, vigilância, entre outros. (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; CAVALCANTE et al., 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018b; Fernandes et al., 2019; LADEGOURDIE; KUA, 2022). A natureza dinâmica desses sistemas, que podem ingressar ou se desconectar do ecossistema urbano a qualquer momento, demanda arquiteturas flexíveis, adaptativas e resilientes (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018a; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022). A operacionalização desses sistemas complexos requer a integração e colaboração entre múltiplas plataformas e serviços heterogêneos, aumentando, assim, a necessidade de interoperabilidade no domínio dos SI (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; CAVALCANTE et al., 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018b; Fernandes et al., 2019; LADEGOURDIE; KUA, 2022). Um exemplo paradigmático dessa integração encontra-se nas cidades inteligentes, onde dispositivos e SI interagem colaborativamente para prover serviços à população, implicando cooperação entre organizações públicas e privadas responsáveis pela gestão desses sistemas (Fernandes et al., 2019).

Nesse contexto, garantir a transparência e a interoperabilidade dos dados entre esses sistemas complexos distribuídos nos SI representa um desafio significativo, uma vez que a interconectividade e a cooperação devem ser mantidas continuamente para o atendimento aos objetivos estabelecidos pelos *stakeholders* (BERNARDINI et al., 2017; FERNANDES et al., 2018). Conforme destacado por Bernardini *et al.* (BERNARDINI et al., 2017), nos "Grandes Desafios da Pesquisa em Sistemas de Informação no Brasil 2016–2026", a transparência e a interoperabilidade são ainda hoje premissas essenciais e complementares, mas são dificultadas pelas distintas políticas de acesso e visibilidade implementadas em cada sistema. Dessa forma, a integração eficiente dos dados em sistemas complexos

distribuídos nos SI permanece como um dos principais desafios contemporâneos da área.

Embora esses avanços proporcionem ganhos em eficiência e autonomia, eles também ampliam as superfícies de ataque e expõem os sistemas a vulnerabilidades de segurança. Diante desse cenário, torna-se fundamental adotar tecnologias que garantam uma comunicação segura, atendendo a requisitos críticos como confiabilidade, integridade e disponibilidade das informações. A dificuldade enfrentada pelos técnicos, especialistas e gestores de TI para lidar com essas questões pode aumentar a exposição a ameaças e os impactos decorrentes de ataques cibernéticos.

Nesse sentido, é essencial implementar mecanismos que assegurem a comunicação entre os sistemas sob a perspectiva da segurança da informação, observando os princípios de confidencialidade, integridade e disponibilidade. Diante desses desafios, o uso de ontologias no domínio da segurança da informação surge como uma abordagem estratégica para superar a heterogeneidade de dados, reduzir ambiguidades conceituais e fortalecer a governança dos sistemas complexos distribuídos no contexto dos SI .

1.2 Motivação

Sistemas complexos, como os *SoS*, *Sistemas Ciberfísicos* (CPS) e *Sistemas Inteligentes*, têm sido amplamente empregados para promover a integração entre diversas áreas no contexto dos SI. Entre os exemplos mais representativos de aplicação desses sistemas, destacam-se as cidades inteligentes, edifícios e infraestruturas inteligentes, manufatura inteligente, medicina inteligente, sistemas de defesa, sistemas móveis, veículos autônomos, entre outros. (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018a; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022).

Com o avanço dessas tecnologias e sua crescente inserção em ambientes críticos, como o das cidades inteligentes e das infraestruturas urbanas, emergem desafios cada vez mais complexos, especialmente no que se refere à segurança e à confidencialidade das informações.

Nas cidades inteligentes, por exemplo, falhas de segurança podem comprometer diretamente a proteção de pessoas e bens patrimoniais, além de gerar impactos significativos sobre a economia local. A integração de infraestruturas críticas e funcionalidades sensíveis exige que os sistemas operem de forma segura, interoperável e confiável. (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012;

ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018a; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022).

Um exemplo concreto dessa necessidade é observado nas usinas nucleares da Eletronuclear — Angra 1, Angra 2 e, futuramente, Angra 3 — nas quais a interoperabilidade entre os sistemas envolvidos é essencial para assegurar uma gestão eficaz e o controle seguro dos processos computacionais e operacionais (LIN; HAGA, 2021a; SANTOS; MELLO, 2022; XUE et al., 2022).

Na Figura 1 são apresentadas as Usinas Termonucleares Angra 1 e Angra 2 e o Centro Nuclear Almirante Álvaro Alberto (CNAAA) [1].

Figura 1: À esquerda, as instalações das Usinas Termonucleares Angra 1 e Angra 2; à direita, o complexo do Centro Nuclear Almirante Álvaro Alberto (CNAAA), composto pelas usinas Angra 1, Angra 2 e Angra 3 (em fase de construção).

1.3 Exemplo Prático, Hipotético e Fictício

Na manhã de uma segunda-feira aparentemente comum, o setor de Tecnologia da Informação (TI) da Instituição Pública Federal Y começou a receber relatos de lentidão no acesso aos sistemas internos. Inicialmente, suspeitou-se de uma instabilidade de rede. Contudo, análises subsequentes revelaram um problema significativamente mais grave: os registros temporais (*timestamps*) estavam atrasados, apesar de os servidores e sistemas de monitoramento indicarem normalidade.

Após investigação aprofundada, identificou-se a presença de um *rootkit* com capacidades de manipulação temporal — um tipo de *malware* sofisticado, silencioso e altamente intrusivo. Esse código malicioso foi introduzido na camada do sistema operacional dos servidores responsáveis por manter a sincronização com a Hora Legal Brasileira [2], utilizando como vetor de entrada a rede interna do Departamento X da instituição (GERGI-

[1] <https://www.eletronuclear.gov.br/Nossas-Atividades/Paginas/default.aspx>

[2] <https://olhardigital.com.br/2025/05/19/ciencia-e-espaco/novo-relogio-atomico-pode-se-tornar-coracao-do-tempo/>

NOV et al., 2025).

O *rootkit* atuava diretamente sobre funções críticas do sistema relacionadas ao tempo, como `gettimeofday()` e os protocolos NTP (Network Time Protocol). Ele manipulava os relógios do sistema de forma seletiva e silenciosa, comprometendo a integridade temporal dos registros e enganando os administradores de rede. Ao inspecionar os logs, os horários aparentavam estar corretos, mas estavam, de fato, desfasados em relação à realidade dos eventos.

Impacto nos Sistemas Governamentais

Diversos sistemas federais críticos passaram a apresentar comportamentos erráticos:

- **SIAFI** [3]: registros contábeis e ordens bancárias gerados com horários inconsistentes;
- **SIAPE** [4]: dados de folha de pagamento e ponto eletrônico corrompidos;
- **SIASG** [5]: falhas nos prazos e históricos de contratos e compras públicas;
- **SCDP** [6]: inconsistências em reservas de passagens e emissões de diárias.

À medida que os dados incorretos eram replicados e processados, os sistemas apresentavam uma espécie de "alucinação computacional" — dados incoerentes, inverossímeis e fora de contexto, em um comportamento análogo aos delírios psicóticos no ser humano.

Impactos Financeiros e nas Estruturas dos Sistemas Governamentais

O ponto mais crítico ocorreu quando os erros temporais afetaram diretamente o SIAFI, responsável por autorizar os pagamentos públicos federais. O sistema passou a emitir ordens bancárias com *timestamps* inválidos, que foram automaticamente transmitidas para os sistemas do Banco do Brasil.

Como a plataforma bancária opera com validações transacionais baseadas em tempo, identificaram-se as seguintes falhas:

[3] http://intra.serpro.gov.br/linhas-negocio/catalogo-de-solucoes/solucoes/principais-solucoes/sistema-integrado-de-administracao-financeira-do-governo-federal-siafi

[4] http://intra.serpro.gov.br/linhas-negocio/catalogo-de-solucoes/solucoes/principais-solucoes/siape-sistema-integrado-de-administracao-de-recursos-humanos

[5] https://www.gov.br/compras/pt-br/acesso-a-informacao/institucional/siasg

[6] https://www.gov.br/compras/pt-br/sistemas/diarias-e-passagens-scdp

Figura 2: Simulação hipotética de um ataque hacker à Divisão de Serviços da Hora Legal Brasileira do Observatório Nacional (ON). Fonte: Divisão do Serviço da Hora do Observatório Nacional (DSHO/ON).

- Rejeição de ordens de pagamento devido a *timestamps* inconsistentes;
- Expiração de tokens de autenticação antes do processamento efetivo;
- Conflitos em conciliações bancárias, com entradas duplicadas ou ausentes;
- Bloqueio de pagamentos a servidores, fornecedores, bolsas e contratos emergenciais.

Embora a infraestrutura de rede estivesse funcional, o tempo — como eixo estruturante da lógica computacional [7] — havia sido comprometido. Como em um surto psicótico, o sistema perdia o contato com a realidade temporal (GERGINOV et al., 2025), mas continuava operando como se estivesse íntegro, demonstrando uma clara perda de *insight* digital.

Diante dessa situação, como mitigar ataques cibernéticos baseados na manipulação temporal por meio de rootkits, que comprometem sistemas integrados dos SI do Governo Federal [8]?

[7] <https://olhardigital.com.br/2025/05/19/ciencia-e-espaco/novo-relogio-atomico-pode-se-tornar-coracao-do-tempo/>

[8] <https://ntp.br/conteudo/estrutura/>

1.4 Problema

Na realidade atual de intensas transformações no cenário político, econômico e social que pressionam os SI, os técnicos, especialistas e gestores podem encontrar muitas dificuldades para gerenciar esses SI nas organizações (JAY, 2013; SMITH; LEWIS, 2011) com foco na segurança da informação (WHITMAN; MATTORD, 2009). Sistemas complexos estão sujeitos a diversas políticas e regras de gerenciamento e controle de numerosas organizações em SI principalmente pela intensa integração dos sistemas. Além disso, a transparência e a interoperabilidade permanecem desafios significativos devido à alta dinamicidade das arquiteturas desses sistemas em SI, conforme destacado por Graciano Neto et al. (2017) . Nesse contexto, falhas relacionadas à segurança da informação — como a perda ou o acesso não autorizado a dados confidenciais durante a comunicação entre os sistemas — podem comprometer o funcionamento do ecossistema como um todo, gerando graves consequências para os negócios.

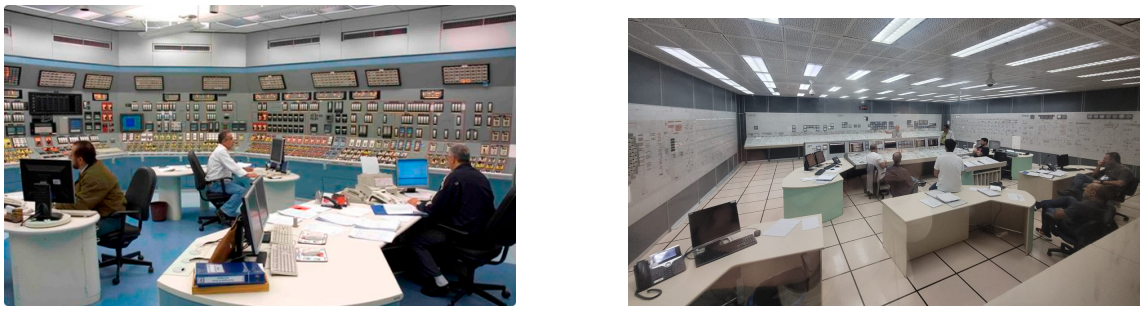
No caso usinas nucleares — como Angra 1, Angra 2 e, futuramente, Angra 3 — operadas pela Eletronuclear[9], a ocorrência de falhas pode comprometer a integridade dos sistemas integrados. Tais falhas podem ocasionar impactos desastrosos à segurança operacional. Assim , ao considerar a necessidade de interoperabilidade entre esses sistemas, torna-se imperativo assegurar a manutenção da interconectividade e da interação, de modo a viabilizar a gestão eficiente e o controle seguro dos respectivos processos e infraestruturas computacionais (LIN; HAGA, 2021a; SANTOS; MELLO, 2022; XUE et al., 2022).

Uma solução promissora para mitigar esses riscos é o uso de ontologias no domínio da segurança, que possibilitam a construção de um modelo de conhecimento compartilhado, promovendo maior segurança e interoperabilidade entre esses sistemas nas diversas áreas.

Na Figura 3 são apresentadas as salas de controle das usinas nucleares Angra 1, a primeira planta nuclear do Brasil, e Angra 2.

Diante disso, este estudo propõe a realização de uma revisão sistemática da literatura com o objetivo de compreender como a academia tem abordado o desenvolvimento e a aplicação de ontologias de segurança em SI. A análise permitirá identificar métodos, técnicas, modelos e ferramentas empregados, avaliar seus desempenhos e mapear componentes impactantes, considerando as três dimensões dos SI: **Processos**, **Pessoas** e **Tecnologias**. Como resultado, pretende-se desenvolver uma taxonomia genérica para estruturar as abordagens existentes, proporcionando uma visão holística sobre o uso de ontologias de segurança em SI.

[9]<https://www.eletronuclear.gov.br/Nossas-Atividades/Paginas/default.aspx>



(a) Sala de controle de Angra 1. **(b)** Sala de Controle de Angra 2

Figura 3: Salas de controle das usinas nucleares Angra 1 (à esquerda), a primeira planta nuclear do Brasil, e Angra 2 (à direita).

1.5 Objetivo

Com base nas características do contexto, motivação e problema, foi possível identificar a principal questão de pesquisa com foco nas três dimensões em SI (Tecnologias, Processos e Pessoas (***QP)***:

QP: *Como as ontologias de segurança têm sido utilizadas no contexto de SI?*

Para ajudar a responder a ***QP***, também foram elaboradas as seguintes subquestões ***(Sub-Q)*** (ver Tabela 1):

Tabela 1: Subquestões de Pesquisa

ID	Subquestão de Pesquisa
Sub-Q1	Como é avaliado o desempenho das ontologias de segurança em SI?
Sub-Q2	Quais componentes impactam o desenvolvimento e aplicação das ontologias de segurança em SI?
Sub-Q3	Quais ferramentas, métodos, modelos e técnicas são utilizados em ontologias de segurança em SI?

Nesse sentido, o objetivo geral desta pesquisa é desenvolver uma **taxonomia multidimensional**, organizada com base nas três dimensões dos SI e nas questões de pesquisa, a fim de proporcionar uma visão integrada e holística sobre o uso de ontologias de segurança em SI.

Tal taxonomia visa:

1. **Compartilhar uma terminologia comum** entre os *stakeholders*, gestores de TI e equipes técnicas, promovendo uma comunicação mais eficiente e precisa, reduzindo ambiguidades e facilitando o alinhamento estratégico

2. **Permitir a reutilização do conhecimento** do domínio, possibilitando que outros pesquisadores apliquem a taxonomia em diferentes contextos (como conformidade regulatória, gestão de riscos ou análise de vulnerabilidades)

3. **Facilitar a classificação sistemática** de conceitos, ameaças, controles e mecanismos de segurança, auxiliando na organização do conhecimento

4. **Servir como fundamento para automação** de processos de segurança, como análise de políticas, detecção de anomalias e resposta a incidentes

5. **Promover a escalabilidade** do modelo, permitindo que a taxonomia seja estendida para abranger novos conceitos emergentes

1.6 Metodologia

As atividades propostas neste projeto de pesquisa conforme a Figura 4 são:

1. Revisão Informal da Literatura para obter uma compreensão aprofundada sobre ontologias de segurança em SI;

2. Mapeamento Sistemático da Literatura (MSL) a partir dos conhecimentos obtidos na atividade 1 sobre o panorama de ontologias de segurança em SI;

3. Construção da taxonomia para explicitar os fatores específicos, as principais metodologias de avaliação e tecnologias abordadas nas ontologias de segurança que foram identificados no MSL.

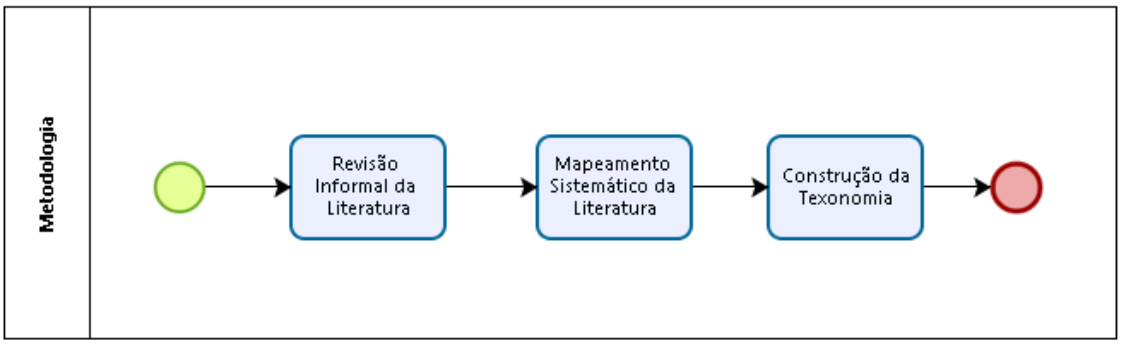


Figura 4: Metodologia aplicada nesta pesquisa.

Na Revisão Informal da Literatura, destacam-se os estudos de Park e Lee (2022) , Hongyi *et al.* (2023) e Lam *et al.* (2024) , por demonstrarem, de forma prática e com potencial de aplicação da academia à indústria, a relevância das ontologias de segurança

no enfrentamento da crescente complexidade da segurança da informação nos SI. Esses autores evidenciam que tais ontologias podem ser utilizadas para reconhecer os níveis de complexidade dos ataques cibernéticos, representar formalmente o conhecimento em segurança da informação e servir como ferramentas de raciocínio automatizado e suporte à decisão para técnicos, especialistas e gestores na área de SI.

No MSL, buscou-se investigar como as ontologias de segurança têm sido aplicadas no contexto de Sistemas de Informação (SI). Foram identificados 19 estudos que apresentam uma diversidade de ferramentas, métodos, modelos e técnicas voltadas para esse propósito. Esses trabalhos oferecem múltiplas perspectivas de análise da temática, aplicando ontologias em diferentes cenários que abrangem as dimensões **Tecnologias**, **Processos** e **Pessoas** da área de SI. Na dimensão **Processos**, destacam-se abordagens relacionadas à análise e avaliação de riscos, bem como à modelagem de ontologias. Na dimensão **Pessoas**, observam-se aplicações práticas em contextos reais, com foco no suporte à tomada de decisão e à gestão do conhecimento. Já na dimensão **Tecnologias**, os estudos evidenciam o desenvolvimento de frameworks, ferramentas e mecanismos de automação, além de iniciativas voltadas à padronização e à melhoria da qualidade em segurança da informação.

A partir do MSL, foram desenvolvidas três taxonomias correspondentes às três subquestões de pesquisa. Em seguida, foi elaborada uma taxonomia integrada e multidimensional, estruturada com base nas dimensões **Processos**, **Pessoas** e **Tecnologias**, proporcionando uma visão holística e integrada sobre o uso de ontologias de segurança em SI.

1.7 Organização

Esta dissertação está organizada em sete capítulos. Neste capítulo de introdução, foram abordados o contexto, a motivação e o problema desta pesquisa. O objetivo e a questão de pesquisa foram construídos conforme o contexto, possibilitando a descrição da metodologia e a organização deste trabalho.

O Capítulo 3 apresenta trabalhos relacionados que evidenciam a relevância do uso de ontologias de segurança da informação como suporte à identificação de ameaças, avaliação de riscos e tomada de decisão em ambientes de SI.

O Capítulo 4 descreve a RSL, por meio do qual foram identificados e analisados estudos relevantes sobre o uso de ontologias de segurança no contexto de SI, contribuindo para a construção das taxonomias propostas.

O Capítulo 5 complementa a RSL ao apresentar três taxonomias fundamentadas em ontologias, aplicadas às dimensões **Tecnologias**, **Processos** e **Pessoas**, respondendo às subquestões delineadas na pesquisa. Além disso, propõe uma taxonomia integrada e multidimensional, que proporciona uma visão holística sobre o uso de ontologias de segurança em SI.

Por fim, Capítulo 6 conclui a pesquisa com algumas considerações finais, apresenta consolidação das contribuições e trabalhos futuros.

2. Fundamentação Teórica

Este capítulo apresenta os principais conceitos e definições utilizados ao longo da pesquisa, além de destacar trabalhos relacionados e finalizar com considerações pertinentes. A organização do capítulo está estruturada da seguinte forma: a Seção 2.1 discute os fundamentos e a definição de ontologias; a Seção 2.2 aborda os aspectos essenciais da segurança da informação; a Seção 2.3 explora os conceitos e aplicações das taxonomias; Seção 2.4 apresenta a metodologia utilizada para o desenvolvimento de uma taxonomia; E por fim, a Seção 2.5 conclui o capítulo com uma síntese da fundamentação teórica no contexto dos Sistemas de Informação (SI).

2.1 Ontologias

No campo da Ciência da Computação, **ontologia** é definida como uma **representação formal, explícita e compartilhada** de uma **conceituação de um domínio**, conforme a definição clássica de Studer, Benjamins e Fensel (1998), fundamentada nos trabalhos de Gruber (1993) e Borst (1997). Nesse contexto, "conceituação" refere-se a um modelo abstrato que identifica os conceitos relevantes de um fenômeno; "explícita" significa que tais conceitos e suas restrições são claramente definidos; "formal" implica que a ontologia pode ser processada por máquinas; e "compartilhada" indica um consenso entre os participantes do domínio.

Complementarmente, ontologias são compreendidas como estruturas que descrevem conjuntos de conceitos e suas inter-relações dentro de um domínio específico, com o objetivo de promover o **compartilhamento, reutilização e interoperabilidade do conhecimento** entre sistemas heterogêneos (NOY; MCGUINNESS, 2001). Ao estabelecer uma base comum de entendimento, as ontologias possibilitam que agentes — humanos ou computacionais — manipulem informações de forma consistente e semântica. Seu uso tem se mostrado especialmente relevante em áreas como engenharia do conhecimento, integra-

ção de dados, recuperação de informação e, em particular, na modelagem de domínios complexos como os Sistemas de Informação e a Segurança da Informação.

Desse modo, a ontologia configura-se como um **artefato computacional essencial para a padronização, organização e estruturação do conhecimento**, viabilizando **inferências automáticas**, **consistência terminológica**, **automatização de processos**, **interoperabilidade entre sistemas** e **melhoria da qualidade da informação**. Ela torna possível representar dados de maneira compreensível e processável por máquinas, o que permite o desenvolvimento de aplicações mais inteligentes e integradas.

2.1.1 Ontologias de Segurança

As **ontologias de segurança** aplicadas a Sistemas de Informação representam modelos formais de conhecimento que estruturam de forma semântica os conceitos, relações e propriedades relevantes ao domínio da segurança da informação. Essas ontologias fornecem um vocabulário padronizado e compartilhado entre sistemas e agentes humanos, promovendo **interoperabilidade**, **raciocínio automatizado** e **suporte à tomada de decisão**. Elas abordam elementos fundamentais como ameaças, vulnerabilidades, ativos, requisitos de segurança, políticas e controles, sendo úteis em atividades como análise de riscos, avaliação de conformidade, definição de políticas e desenvolvimento seguro de sistemas.

Essas estruturas são comumente desenvolvidas utilizando linguagens formais, como a **OWL (Web Ontology Language)**, o que permite uma representação precisa do conhecimento e a realização de inferências automáticas. Ao capturar o conhecimento especializado em segurança, as ontologias possibilitam que diferentes organizações e sistemas compreendam e processem informações críticas de maneira coerente. Além disso, favorecem a **reutilização de modelos preexistentes**, assegurando **modularidade** e **extensibilidade** para diversos contextos e domínios.

Diversos estudos destacam a aplicação de ontologias de segurança em diferentes cenários. Fenz e Ekelhart (2009) propuseram uma ontologia voltada à formalização do conhecimento para análise automatizada de riscos. Brucker e Petritsch (2015) modelaram políticas de autorização aplicáveis em tempo de execução. Kotenko e Doynikova (2016) empregaram ontologias na análise inteligente de dados de segurança em sistemas distribuídos. Ramanauskaite et al. (2013) exploraram sua utilidade em análises quantitativas de risco, enquanto Blanco et al. (2008) realizaram uma revisão sistemática comparando diversas ontologias de segurança.

Dessa forma, as ontologias de segurança nos SI constituem **ferramentas estratégicas para a representação formal e reutilizável do conhecimento**, favorecendo a padronização, automação e eficiência das práticas de segurança da informação.

A Figura 6 apresenta um exemplo ilustrativo de ontologia voltada à segurança da informação (LIN; HAGA, 2021b).

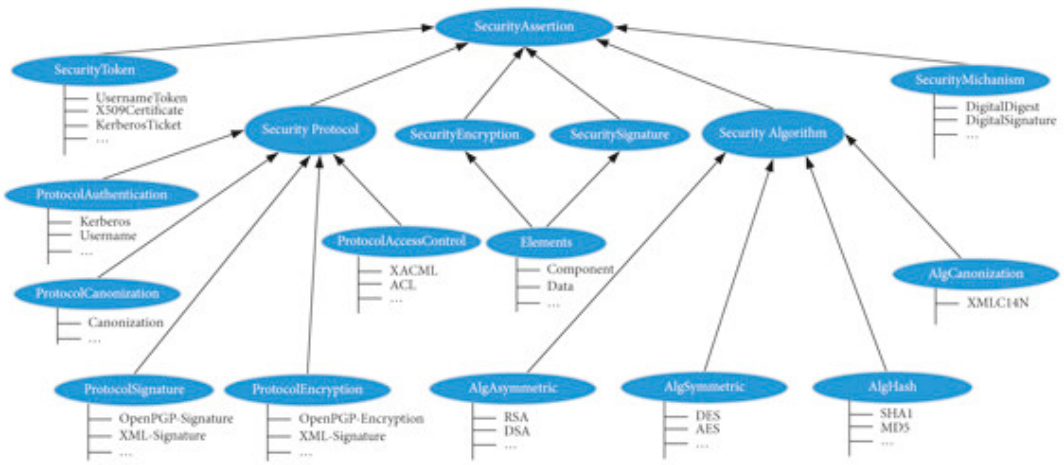


Figura 5: Exemplo de ontologia de segurança.

2.2 Segurança da Informação

A norma internacional **ISO/IEC 27002:2013** (ISO, 2013) estabelece que a segurança da informação deve ser alcançada por meio da implementação de um conjunto apropriado de controles. Esses controles incluem políticas, processos, procedimentos, estruturas organizacionais e mecanismos técnicos de software e hardware. Para garantir sua eficácia, é necessário que esses controles sejam formalmente definidos, implantados, monitorados, avaliados criticamente e continuamente aprimorados. Esse processo assegura a conformidade com os objetivos organizacionais e os requisitos de segurança da informação.

Em complemento a essa abordagem normativa, Whitman e Mattord (WHITMAN; MATTORD, 2009) definem a segurança da informação (InfoSec) como a proteção dos dados e de seus elementos críticos, incluindo os sistemas que os armazenam, processam e transmitem. Os autores destacam a importância de propriedades fundamentais da informação, com ênfase na chamada **tríade CID — confidencialidade**, **integridade** e **disponibilidade** (MALAGUTTI, 2016).

A **confidencialidade** assegura que apenas indivíduos autorizados tenham acesso à in-

formação; a **integridade** garante que os dados permaneçam corretos, íntegros e autênticos; e a **disponibilidade** refere-se à capacidade dos sistemas de manterem os dados acessíveis e operacionais conforme os requisitos do negócio (DHILLON; KOLKOWSKA, 2011; OUEDRAOGO et al., 2015). Além desses pilares, outras propriedades como **precisão, autenticidade, utilidade** e **posse** também são consideradas essenciais para a proteção da informação no contexto organizacional (WHITMAN; MATTORD, 2009).

Para garantir essas propriedades, diversas soluções tecnológicas têm sido implementadas, sendo a **criptografia** uma das mais relevantes. Essa técnica protege a informação ao codificar dados de forma que apenas destinatários autorizados possam decifrá-los. Destacam-se os métodos baseados em **chave privada**, como o **RSA** e as **curvas elípticas**, que oferecem elevados níveis de segurança. Recentemente, soluções baseadas em **criptografia orientada a atributos** vêm ganhando destaque por facilitarem a colaboração segura e a interoperabilidade entre recursos heterogêneos nos Sistemas de Informação (PIETZ et al., 2014).

2.3 Taxonomia

A **taxonomia** é definida como um **sistema de classificação estruturado**, que organiza o conhecimento em categorias hierárquicas. Seus principais objetivos são: (1) organizar conceitualmente o universo informacional; (2) padronizar a comunicação especializada; e (3) otimizar os processos de armazenamento e recuperação da informação (BRASILEIRO et al., 2019a).

O termo tem origem no grego antigo — *taxis* (ordenação) e *nomos* (norma) — refletindo sua natureza sistemática. Embora tradicionalmente associada à biologia, sua aplicação estende-se a diversas áreas, incluindo a ciência da informação, a gestão do conhecimento e os Sistemas de Informação (SI).

Nas organizações contemporâneas, a taxonomia desempenha papel crucial na **estruturação de dados**, **gestão do conhecimento** e **melhoria da recuperação da informação** (CAMPOS; GOMES, 2008b; AGANETTE et al., 2010). Em um cenário marcado pela sobrecarga informacional, taxonomias tornam-se ferramentas essenciais para alinhar a organização da informação aos objetivos institucionais e às necessidades dos usuários. Sua abordagem sistemática e flexível a torna indispensável tanto para fins científicos quanto para o contexto corporativo.

2.4 Etapas do Desenvolvimento da Taxonomia

Esta seção descreve as etapas adotadas para o desenvolvimento da taxonomia da Figura 6), fundamentadas na pesquisa em SI, conforme (ARAUJO et al., 2017), e baseadas na abordagem de modelagem de taxonomias adaptada por (BRASILEIRO et al., 2019b) com base no estudo de (CAMPOS; GOMES, 2008a). A construção seguiu uma abordagem sistemática composta pelas seguintes etapas:

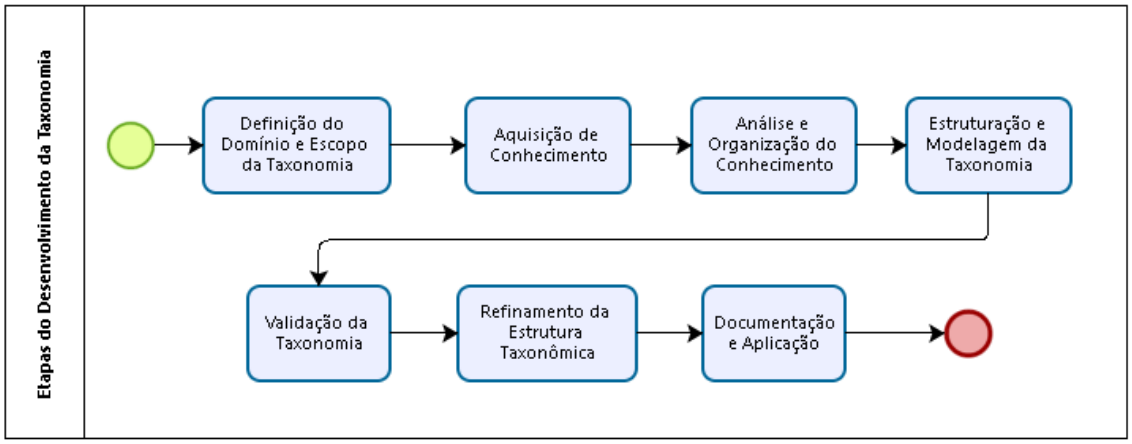


Figura 6: Etapas do Desenvolvimento da Taxonomia.

1. **Definição do Domínio e Escopo da Taxonomia**: Etapa voltada à delimitação do escopo conceitual, definição do propósito, dos objetivos, dos usuários-alvo e do tipo de taxonomia a ser desenvolvida, orientando sua estruturação e aplicação.

2. **Aquisição de Conhecimento**: Consiste na coleta sistemática de informações relevantes sobre o domínio, com base em literatura científica, documentos técnicos, normas, padrões e demais fontes especializadas.

3. **Análise e Organização do Conhecimento**: Fase dedicada à identificação, definição, categorização e agrupamento dos termos relevantes, com base na rastreabilidade das fontes coletadas na etapa anterior.

4. **Estruturação e Modelagem da Taxonomia**: Construção da estrutura conceitual da taxonomia, por meio da definição de categorias, subcategorias e relações hierárquicas, seguida de sua modelagem formal por meio de esquemas, tabelas ou diagramas.

5. **Validação da Taxonomia**: Avaliação da consistência, clareza e aplicabilidade da taxonomia, realizada por meio de revisão por especialistas e testes em cenários representativos dos contextos acadêmico e industrial.

6. **Refinamento da Estrutura Taxonômica**: Ajustes e aprimoramentos na estrutura conceitual com base nos resultados obtidos na etapa de validação, garantindo maior precisão, coerência interna e aderência ao domínio.

7. **Documentação e Aplicação**: Registro formal da taxonomia final, incluindo sua estrutura, critérios metodológicos e orientações de uso, de modo a promover sua reutilização, disseminação e aplicabilidade prática.

2.5 Considerações Finais

Este capítulo apresentou os fundamentos teóricos que embasam esta pesquisa, com foco nas ontologias, segurança da informação, taxonomias e trabalhos relacionados. Destacou-se o papel das ontologias como instrumentos formais para representação e organização do conhecimento em segurança, promovendo interoperabilidade e automação. A segurança da informação foi discutida com base na tríade confidencialidade, integridade e disponibilidade, além de mecanismos e normas relevantes para sua garantia. Por fim, a taxonomia foi compreendida como estrutura essencial para classificação e recuperação de conhecimento, especialmente em contextos organizacionais ligados aos SI.

3.Trabalhos Relacionados

Este capítulo está organizado da seguinte forma: a Seção 5.1 apresenta uma breve introdução ao levantamento realizado; a Seção 3.2 discute os principais trabalhos identificados na literatura; e, por fim, a Seção 5.3 traz considerações finais sobre os estudos analisados.

3.1 Introdução

A partir de um levantamento *ad hoc* da literatura, foram identificadas três pesquisas recentes que propõem o uso de ontologias de domínio como solução para desafios no contexto de Sistemas de Informação (SI). A análise do desenvolvimento dessas propostas permitiu identificar uma lacuna nos estudos existentes, evidenciando uma oportunidade para o desenvolvimento da presente pesquisa.

3.2 Contexto

A literatura atual apresenta uma diversidade de estudos relevantes sobre o uso de ontologias aplicadas à segurança da informação. Dentre eles, destacam-se os trabalhos de Park e Lee (2022) , Hongyi *et al.* (2023) e Lam *et al.* (2024) , que exploram diferentes aspectos do emprego de ontologias no âmbito dos SI.

Park e Lee (2022) observaram que os ataques cibernéticos com impactos comerciais têm se tornado cada vez mais sofisticados, sendo frequentemente compostos por múltiplos elementos interligados. Como exemplo, destacam-se as ameaças persistentes avançadas (APT), que representam um desafio significativo. Os autores argumentam que, embora métodos tradicionais de gerenciamento de risco possam ser aplicados, eles enfrentam limitações, especialmente por se basearem em avaliações qualitativas orientadas por ativos.

Como alternativa, propõem uma ontologia de domínio voltada à Consciência de Riscos, especializada na avaliação de riscos relacionados a APTs. Essa ontologia incorpora elementos como componentes de ataque, risco, requisitos de segurança e estratégias de mitigação.

Hongyi *et al.* (2023) abordam a complexidade e a dinamicidade das atividades de ataque cibernético. Para lidar com esse cenário, os autores propõem a expansão da *Upper Cybersecurity Ontology* (UCO) e o desenvolvimento de uma nova ontologia adaptada às características do conjunto de dados CS13K, reutilizando ontologias de segurança já existentes. Além disso, utilizam a ferramenta *Neo4j*[1] para a construção de um grafo de conhecimento em segurança cibernética, com o objetivo de promover maior consciência situacional e facilitar a identificação de ameaças nas organizações.

Já Lam *et al.* (2024) desenvolveram o sistema VALARIN (*Verifiable Automatic Language Analysis and Recognition for Inputs*), que visa analisar divergências entre diferentes analisadores de arquivos PDF para identificar e classificar erros relacionados à segurança. Para apoiar esse processo, os autores elaboraram uma ontologia de domínio em SI, permitindo a representação estruturada do conhecimento e o raciocínio automatizado. Os erros identificados são organizados em uma ontologia hierárquica, o que facilita sua categorização. A ferramenta *Protégé*[2] foi empregada na modelagem da ontologia, enquanto analisadores como *xpdf*, *pdfbox*, *mutool* e *poppler* foram utilizados na extração de dados e geração de relatórios de erros.

Esses estudos reforçam a relevância do uso de ontologias de segurança da informação como suporte à identificação de ameaças, avaliação de riscos e apoio à tomada de decisão em ambientes de SI.

3.3 Considerações Finais

A análise dos trabalhos relacionados permitiu identificar abordagens relevantes que utilizam ontologias de domínio como ferramentas eficazes para enfrentar desafios complexos no contexto da segurança da informação em Sistemas de Informação. Em especial, os estudos discutidos evidenciam a aplicabilidade das ontologias na modelagem de ameaças e riscos, na integração e estruturação de dados, na construção de grafos de conhecimento e na detecção automatizada de vulnerabilidades.

[1] <https://neo4j.com/>
[2] <https://protege.stanford.edu/>

Cada uma das pesquisas analisadas aborda aspectos específicos da segurança da informação, como APTs, análise de vulnerabilidades em arquivos PDF ou a representação de dados oriundos de conjuntos específicos. De forma geral, os trabalhos revisados reforçam o papel estratégico das ontologias de segurança na identificação, categorização e mitigação de ameaças em SI, além de evidenciarem o potencial dessas abordagens para apoiar soluções mais robustas e automatizadas no domínio da cibersegurança.

4. Revisão Sistemática da Literatura

Este capítulo está organizado da seguinte forma. A Seção 4.1 traz a motivação e justificativa para a revisão sistemática realizado nesta pesquisa. A Seção 4.2 apresenta a metodologia, detalhando o planejamento e execução da revisão. A Seção 4.3 apresenta as limitações da revisão sistemática. A Seção 4.4 aborda a discussão dos resultados. Finalmente, a Seção 4.5 fornece uma visão geral da contribuição da revisão sistemática para a pesquisa.

4.1 Introdução

As transformações no cenário econômico e social tornaram o controle da Segurança da Informação mais complexo. A crescente integração de sistemas, impulsionada pelas *APIs* (*Application Programming Interfaces*), destacou a necessidade de conectar diferentes tipos de sistemas complexos, como *Sistemas de Sistemas* (SoS), *Sistemas Ciberfísicos* (CPS) e *Sistemas Inteligentes*. Essa integração exige colaboração entre diversas plataformas e serviços, ampliando a demanda da interoperabilidade nos SI.

Apesar dos ganhos em eficiência e autonomia, a integração expõe vulnerabilidades de segurança, exigindo tecnologias que garantam comunicação segura e atendam a requisitos como confiabilidade, integridade e disponibilidade. A dificuldade de gestão desses aspectos pode aumentar a exposição a ameaças e ataques cibernéticos.

Nesse contexto, é essencial adotar mecanismos que assegurem a segurança na comunicação entre sistemas, com foco nos princípios de confidencialidade, integridade e disponibilidade (ISO, 2013). Diante desses desafios, o uso de ontologias em segurança da informação surge como solução estratégica para superar a heterogeneidade de dados, reduzir ambiguidades conceituais e fortalecer a governança da informação em ambientes complexos.

Este estudo propõe uma **revisão sistemática da literatura** (RSL) para compreender como a academia tem tratado o desenvolvimento e uso de ontologias de segurança em SI. A análise visa identificar ferramentas, métodos, modelos e técnicas utilizados, avaliar seu desempenho e mapear componentes relevantes nas dimensões: **Pessoas**, **Processos** e **Tecnologias**.

4.2 Protocolo e Execução

Este estudo teve como base investigar as ontologias de segurança da informação, visando obter um melhor entendimento de como esse tema é abordado na literatura científica, considerando o contexto, o domínio e os tipos de soluções aplicadas em SI. A partir das diretrizes de (KITCHENHAM; CHARTERS, 2007), foi elaborado um protocolo para execução da revisão sistemática, composto pelas seguintes fases: (1) Planejamento, (2) Execução e (3) Apresentação dos Resultados.

4.2.1 Planejamento

4.2.1.1 Questão de Pesquisa:

Visando expressar os objetivos deste estudo, a questão de pesquisa (QP) foi formulada seguindo os critérios especificados no PIO (*Population*, *Intervention* e *Outlines*), como pode ser visto na Tabela 2.

Tabela 2: Critérios de PIO

População	Segurança da Informação e Sistemas de Informação
Intervenção	Tecnologias de Segurança da Informação
Resultados	Técnicas / Modelos / Métodos / Ferramentas

Com isso, foi formulada a seguinte questão de pesquisa (***QP***): **QP**: *Como as ontologias de segurança têm sido utilizadas no contexto de SI?* Para ajudar a responder a ***QP***, também foram elaboradas as seguintes subquestões ***(Sub-Q)*** (ver Tabela 2):

Tabela 3: Subquestões de Pesquisa

ID	Subquestão de Pesquisa
Sub-Q1	Quais ferramentas, métodos, modelos e técnicas são utilizadas no desenvolvimento de ontologias de segurança, considerando as dimensões pessoas, processos e tecnologia em SI
Sub-Q2	Como é avaliado o desempenho das ontologias de segurança, considerando as dimensões pessoas, processos e tecnologia em SI?
Sub-Q3	Quais componentes impactam o desenvolvimento e a aplicação das ontologias de segurança em cada uma das dimensões de SI?

4.2.1.2 Fontes de Busca:

As buscas eletrônicas foram realizadas na base Scopus[1] e nas bibliotecas digitais ACM Digital Library[2], IEEE Xplore[3], Science Direct[4] e Springer Link[5]. Essas bases de dados foram escolhidas, pois armazenam um grande volume de estudos científicos relevantes da área de Ciência da Computação, seguindo as recomendações de Dyba et al. (2007).

4.2.1.3 Definição dos Termos de Pesquisa:

Para a pesquisa nas bases de dados definidas, foi criada uma *string* de busca com a junção dos termos e sinônimos, que representam a população e a intervenção que compõem os critérios PIO apresentados na Tabela 2. Após a realização de alguns testes, chegou-se à seguinte *string* de busca: *("**Domain ontology**" AND "**information security**")*

4.2.1.4 Critérios de Seleção dos Estudos:

A Tabela 4 descreve os critérios de inclusão (CI) e exclusão (CE) aplicados sobre os estudos retornados pela *string* de busca, conforme Kitchenham e Charters (KITCHENHAM; CHARTERS, 2007).

Tabela 4: Critérios de Seleção

Categoria	Código	Descrição
Critérios de Inclusão		
	CI1	Estudos com acesso disponível.
	CI2	Estudos que abordam ontologias de segurança em SI.
	CI3	Estudos publicados depois de 2019.
Critérios de Exclusão		
	CE1	Estudos com leitura integral bloqueada.
	CE2	Estudos como artigos curtos ou pôsteres.
	CE3	Estudos duplicados e/ou que reportam resultados de outro estudo (neste caso, será considerado o estudo mais atual para a análise).
	CE4	Estudos que não estão escritos em inglês.
	CE5	Estudos que não abordam o tema.
	CE6	Estudos que não respondem a pelo menos uma das perguntas de pesquisa.
	CE7	Estudos publicados antes de 2019.

[1]https://www.scopus.com/
[2]https://dl.acm.org/
[3]https://ieeexplore.ieee.org/Xplore/home.jsp
[4]https://www.sciencedirect.com/
[5]https://ihttps://link.springer.com/

4.2.2 Execução

4.2.2.1 Processo de Seleção dos Estudos

A Figura 7 mostra o processo de seleção dos estudos, e a quantidade de estudos excluídos e motivo em cada etapa.

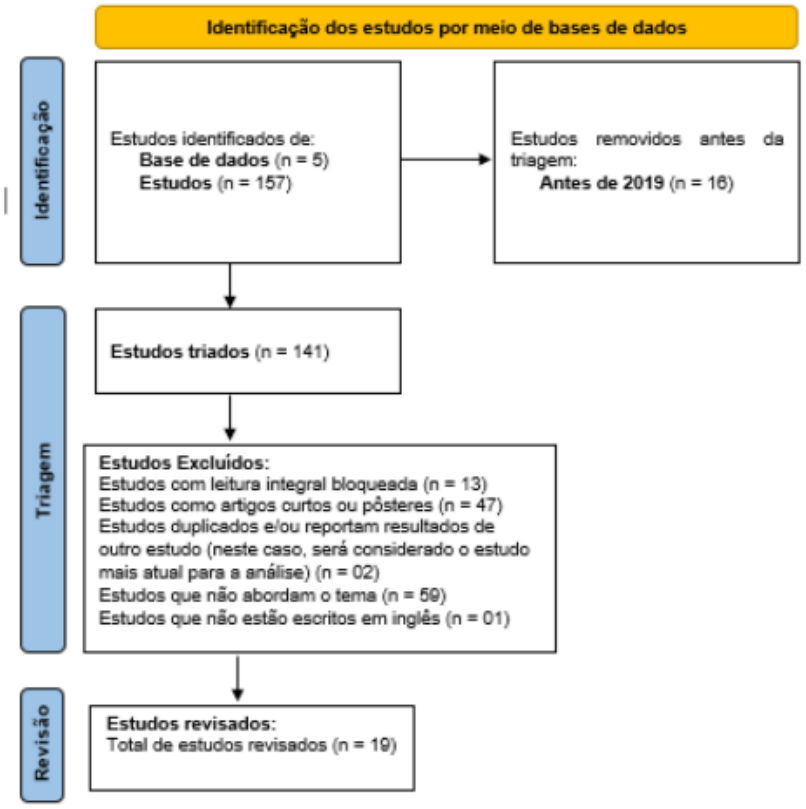


Figura 7: Processo de seleção de estudos.

O processo de seleção será composto por quatro etapas:

- **Identificação:** Nesta etapa, realizou-se a busca e exclusão de estudos publicados antes de 2019. A escolha deste corte temporal, abrangendo os últimos cinco anos, se justifica pela rápida evolução das tecnologias na área de Ciência da Computação. Estudos anteriores a essa data podem não refletir as tendências, avanços e práticas atuais, tornando-se, portanto, menos relevantes para nossa análise.

- **Triagem:** Esta fase consiste na avaliação dos estudos para garantir que se enquadrem nos critérios de inclusão e exclusão previamente estabelecidos.

- **Revisão:** Envolve uma análise detalhada e avaliação crítica dos estudos selecionados, visando extrair informações relevantes para nossa pesquisa.

O processo de seleção dos estudos foi executado nas bases na última semana mês de setembro de 2024 e a filtragem dos resultados ocorreu em 3 etapas.

Na etapa 1, foi executada a busca eletrônica com a string de pesquisa nas bases selecionadas, sendo retornados o total de 157 estudos. Esses estudos foram armazenados na ferramenta Parsifal[6], que facilita a organização, filtragem, categorização e revisão dos estudos, para execução das demais etapas.

Na etapa 2, foram excluídos os seguintes tipos de estudos: aqueles com leitura integral bloqueada (13 estudos), artigos curtos ou pôsteres (47 estudos), estudos duplicados ou que reportam resultados de outros estudos (2 estudos), estudos que não abordam o tema central (59 estudos) e, por último, estudos que não estão escritos em inglês (1 estudo).

Por fim, na etapa 3, foram selecionados 19 estudos para a análise de dados e a coleta de respostas às questões de pesquisa.

4.2.3 Levantamento de Dados

Foram selecionados 19 estudos sobre ontologias de segurança em SI, os quais apresentam uma variedade de métodos, técnicas, modelos e ferramentas.
Esses estudos também abordam o desempenho das ontologias e os componentes que impactam seu desenvolvimento e aplicação, conforme apresentado na Tabela 5. A tabela está organizada em colunas que indicam o ID, título, autores e ano de publicação de cada estudo, de forma a facilitar a identificação e análise das referências selecionadas. O processo de extração, conforme citado acima, foi realizado sistematicamente, com o auxílio da ferramenta Parsifal[7] para o registro de informações necessárias para responder às questões de pesquisa.

4.3 Apresentação dos resultados

Foram selecionados 19 estudos sobre ontologias de segurança em Sistemas de Informação, os quais apresentam uma variedade de métodos, técnicas, modelos e ferramentas. Esses estudos também abordam o desempenho das ontologias e os componentes que impactam seu desenvolvimento e aplicação, conforme apresentado na Tabela 5. A tabela 5 está organizada em colunas que indicam o ID, título, autores e ano de publicação de cada estudo, de forma a facilitar a identificação e análise das referências selecionadas.

[6]https://parsif.al/
[7]https://parsif.al/

4.3.1 Dados demográficos

A **Figura** 8 apresenta a cronologia dos 19 estudos selecionados. Em 2020, não houve publicações, possivelmente em decorrência dos impactos iniciais da pandemia e das medidas de lockdown. No entanto, em 2021, as publicações foram retomadas, indicando uma adaptação ao novo cenário.

A partir de 2022, registrou-se um crescimento acentuado no número de publicações, reflexo das transformações tecnológicas aceleradas pela pandemia. Esse fenômeno não apenas evidenciou a maior relevância do tema, mas também impulsionou o interesse e o incentivo à pesquisa na área.

Assim, a **Figura** 9 ilustra uma mudança no paradigma da produção científica, com países emergentes assumindo um papel mais ativo nas publicações sobre segurança em SI. Essa tendência reforça o crescente engajamento global em torno do assunto.

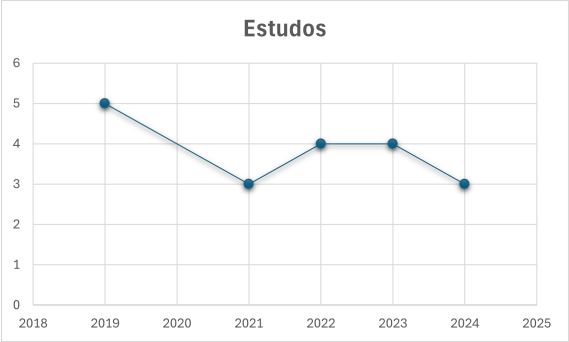


Figura 8: Quantidade de estudos publicados por ano.

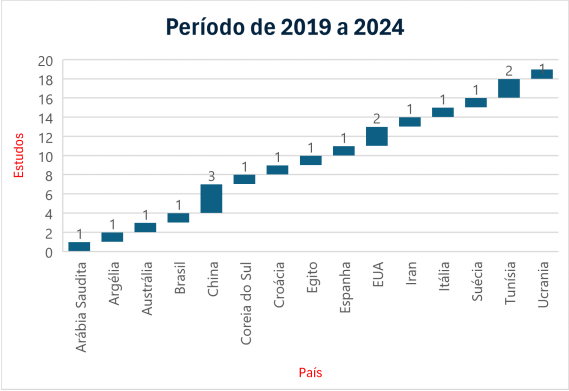


Figura 9: Quantidade de estudos publicados por país.

Tabela 5: Dados extraídos dos estudos selecionados

ID	Título	Autores	Ano
E1	A First Step Towards an ISO-Based Information Security Domain Ontology	Casola, V.; Catelli, R.; De Benedictis, A.	2019
E2	STRAM: Measuring the Trustworthiness of Computer-Based Systems	Cho, J.-H.; Xu, S.; Hurley, P. M.; Mackay, M.; Benjamin, T.; Beaumont, M.	2019
E3	An Ontology-Based Model for User Profile Building Using Social Networks	Niyazova, R.; Aktayeva, A.; Davletkireeva, L.	2019
E4	Comparative Study of Ontologies Based on ISO 27000 Series Security Standards	Meriah, I.; Ben Arfa Rabai, L.	2019
E5	An ontology-driven framework for knowledge representation of digital extortion attacks	Keshavarzi, M.; Ghaffary, H. R.	2019
E6	Ontology-Based Approach to Validation of Learning Outcomes for Information Security Domain	Rogushina, J. V.; Gladun, A. Y.; Pryima, S. M.; Strokan, O. V.	2019
E7	Applying Multi-Level Theory to an Information Security Incident Domain Ontology	Faria, M. R.; Figueiredo, G. B.; Cordeiro, K. F.; Cavalcanti, M. C. R.; Campos, M. L. M.	2019
E8	Social Engineering in Cybersecurity: A Domain Ontology and Knowledge Graph Application Examples	Wang, Z.; Zhu, H.; Liu, P.; Sun, L.	2019
E9	Towards an Automatic Approach to the Design of A Generic Ontology for Information Security	Meriah, I.; Rabai, L. B. A.; Khedri, R.	2021
E10	A Combined Security Ontology Based on the Unified Foundational Ontology	Adach, M.; Hänninen, K.; Lundqvist, K.	2022
E11	Threat-Driven Risk Assessment for APT Attacks Using Risk-Aware Problem Domain Ontology	Park, S.-H.; Lee, S.-W.	2022
E12	Multiontology Construction and Application of Threat Model Based on Adversarial Attack and Defense Under ISO/IEC 27032	Hu, X.; Cheng, D.; Chen, J.; Jin, X.; Wu, B.	2022
E13	A Framework for Conceptual Characterization of Ontologies and Its Application in the Cybersecurity Domain	Martins, B. F.; Serrano Gil, L. J.; Reyes Román, J. F.; Panach, J. I.; Pastor, Ó.; Hadad, M.; Rochwerger, B.	2022
E14	Ontology-Based Cybersecurity for Well-Being, Aging and Health: A Scoping Review	Belani, H.; Šolić, P.; Perković, T.; Zovko, K.	2023
E15	APKOWL: An Automatic Approach to Enhance the Malware Detection	Aboshady, D.; Ghannam, N. E.; Elsayed, E. K.; Diab, L. S.	2023
E16	Cybersecurity Knowledge Graphs	Sikos, L. F.	2023
E17	PDF Investigation With Parser Differentials and Ontology	Lam, D.; Li, L.; Anderson, C.	2024
E18	Integrated Interaction Journey and Privacy Risk Assessment: A Graph Model	Alabsi, M.; Gill, A.; Bandara, M.	2024
E19	Cybersecurity Knowledge Graphs Construction and Quality Assessment	Li, H.; Shi, Z.; Pan, C.; Zhao, D.; Sun, N.	2024

4.3.2 Limitações

Este estudo apresenta algumas limitações, como, por exemplo, a string de busca, pode ter limitado o número de estudos retornados. Além disso, bases como Scopus e ACM Digital Library apresentaram estudos bloqueados. Dessa forma, este estudo pode ser expandido no futuro com uma string de busca mais ampla e com maior acesso a essas respectivas bases.

4.4 Análise dos Resultados

Para responder à QP, os dados coletados foram analisados com base nas respostas das **Sub-Q**:
Sub-Q1: *Quais ferramentas, métodos, modelos e técnicas são utilizadas no desenvolvimento de ontologias de segurança, considerando as dimensões pessoas, processos e tecnologia em SI?*

A análise dos estudos evidencia que a aplicação de ontologias de segurança em SI se estrutura com base em três dimensões fundamentais: **Pessoas**, **Processos** e **Tecnologias** (LAUDON; LAUDON, 2020).
Na dimensão das **Pessoas**, destacam-se ontologias de segurança aplicadas em cenários reais, com ênfase na modelagem do comportamento, perfil e fatores psicossociais dos usuários no contexto da segurança da informação. Essa dimensão abrange a análise de atitudes, conscientização e treinamento em práticas seguras, bem como a gestão dos riscos humanos associados a vulnerabilidades como engenharia social e erros operacionais. Ressalta-se a importância da incorporação do fator humano para a mitigação de ameaças, fortalecimento da postura de segurança e redução de incidentes relacionados a falhas humanas nos sistemas de informação.

- **Aplicações práticas em cenários reais:** Os estudos analisados evidenciam diferentes formas de aplicação dessas ontologias. O estudo **E5** utiliza a ontologia ***Rantology*** para reforçar a **segurança digital dos usuários**, reduzindo o impacto de ataques cibernéticos direcionados. No estudo **E8**, é proposta uma **ontologia de domínio voltada à engenharia social**, aplicada à **análise de cenários reais por meio de grafos de conhecimento**. Essa abordagem permite mapear o ciclo de ataques que exploram vulnerabilidades humanas — como confiança e curiosidade — contribuindo para a **prevenção e educação dos usuários**.

Na dimensão dos **Processos**, dois eixos principais se destacam:

- **Análise e avaliação de riscos**: Representada pelo estudo **E1**, que é uma base fundamental em um Sistema de Gestão de Segurança da Informação (SGSI), vinculando-a diretamente aos requisitos da norma ISO/IEC 27001 e aos processos de verificação de controles de segurança. O estudo **E2** também estabelece a análise de riscos como metodologia essencial para mensuração da confiabilidade de sistemas. Já o estudo **E4** propõe a utilização de ontologias de segurança, relacionadas à ISO 27005, como um processo de avaliação e tratamento de riscos, enquanto o estudo **E10** desenvolve este processo por meio da Ontologia de Segurança Combinada (do inglês, *Common Security Ontology* ou **CSO**), que operacionaliza o conceito de risco com base em padrões reconhecidos, como o NIST SP 800-30. O estudo **E11** propõe um modelo específico para avaliação de riscos relacionados a ataques APT (*Advanced Persistent Threat*), integrando requisitos de segurança e componentes de risco. Paralelamente, o estudo **E13** emprega a norma ISO/IEC 27005:2011 como *framework* para gestão de riscos, realizando uma análise conceitual detalhada do risco no contexto da cibersegurança. O estudo **E18** apresenta uma contribuição aplicada para avaliação de riscos de privacidade baseada no NIST 800-30, com implementação prática em ambientes de aeroportos inteligentes.

- **Modelagem de ontologias**: O estudo **E1** apresenta um modelo baseado em ontologia para gestão de documentos em Sistemas de Gestão de Segurança da Informação (SGSI), com duas camadas de abstração ontológica, detalhando o uso da ferramenta Protégé para modelagem de uma ontologia de segurança da informação alinhada à ISO. O estudo **E5** descreve o design e a implementação da ontologia dedicada ao domínio das chantagens digitais, denominada **Rantology**, voltada para ataques de extorsão digital, utilizando uma abordagem iterativa de sete passos e sendo expressa em OWL. O estudo **E8** apresenta o processo de definição de relações em uma ontologia de domínio, com implementação no Protégé e exportação para o Neo4j para construção de grafo de conhecimento. Já o estudo **E9** propõe um método automático para o design de uma ontologia genérica de segurança da informação, com etapas que envolvem a coleta automatizada de dados online (web scraping), classificação de conceitos e processos de design manual, semiautomático e automático. O estudo **E10** discute a implementação da CSO, utilizando diagramas UML e metodologias como CommonKADS e Methontology. O estudo **E12** detalha a construção de uma estrutura multi-ontológica composta por três camadas: ontologia generalizada, ontologia de domínio (ataque e defesa) e ontologia de aplicação (baseada em padrões como ISO/IEC 27032 e MITRE ATT&CK). A interconexão dessas ontologias permite uma modelagem de ameaças sistemática e orientada por conhecimento, que aprimora a análise de cenários adversariais e a identificação de falhas de segurança.

O estudo **E15** apresenta o método denominado **APKOWL** para a construção automática de uma ontologia em OWL (Web Ontology Language) que modela a estrutura de malwares. Por fim, o estudo **E17** descreve o desenvolvimento de uma ontologia em OWL para programas projetados para interpretar o conteúdo de um arquivo PDF (Portable Document Format).

A Tabela 6 apresentadas a seguir, a síntese das dimensões Pessoas e Processos como às respostas da Sub-Q1.

Tabela 6: Estudos relacionados ao uso de ontologias em Segurança da Informação por dimensão e abordagem.

Dimensão: Pessoas		
Aplicações Práticas		
Estudo	**Descrição**	**Tipo**
E5	Ontologia *Rantology* para mitigar ataques de extorsão digital e proteger usuários.	Aplicações Práticas
E8	Ontologia sobre engenharia social aplicada a cenários reais com grafos de conhecimento.	Aplicações Práticas
Dimensão: Processos		
Análise e Avaliação de Riscos		
Estudo	**Descrição**	**Tipo**
E1	Avaliação de riscos conforme ISO/IEC 27001 no contexto de SGSI.	Análise de Riscos
E2	Mensuração da confiabilidade de sistemas via análise de riscos.	Análise de Riscos
E4	Avaliação e tratamento de riscos com base na ISO/IEC 27005.	Análise de Riscos
E10	Ontologia CSO baseada no NIST SP 800-30 para modelar riscos.	Análise de Riscos
E11	Avaliação de riscos para ataques APT com integração de requisitos.	Análise de Riscos
E13	Análise conceitual de riscos com base na ISO 27005 e NIST 800-30.	Análise de Riscos
E18	Avaliação de riscos de privacidade em aeroportos inteligentes.	Análise de Riscos
Modelagem de Ontologias		
Estudo	**Descrição**	**Tipo**
E1	Ontologia para SGSI construída no Protégé, alinhada à ISO.	Modelagem Ontológica
E5	Ontologia Rantology em OWL voltada a chantagens digitais.	Modelagem Ontológica
E8	Ontologia sobre engenharia social, exportada para Neo4j.	Modelagem Ontológica
E9	Método semiautomático de design ontológico com coleta online.	Modelagem Ontológica
E10	CSO modelada com UML, CommonKADS e Methontology.	Modelagem Ontológica
E12	Estrutura multi-ontológica baseada em ISO/IEC 27032 e MITRE.	Modelagem Ontológica
E15	APKOWL: construção automática de ontologia sobre malware.	Modelagem Ontológica
E17	Ontologia OWL para leitura semântica de arquivos PDF.	Modelagem Ontológica

Na dimensão das **Tecnologias**, destacam-se ontologias de segurança organizadas nas seguintes categorias:

- **Desenvolvimento de Frameworks**: O estudo **E1** propõe um framework para Sistemas de Gestão de Segurança da Informação (SIEM) baseado em uma ontologia de dupla camada, integrando conceitos das normas ISO 27000. Essa abordagem so-

luciona inconsistências presentes na ISO 27002 por meio da padronização de dados com o uso da *Basic Formal Ontology* (BFO) e da linguagem OWL, promovendo maior consistência e interoperabilidade entre os componentes do sistema. O estudo **E2** apresenta o STRAM (*Security, Trust, Resilience, and Agility Metrics*), um framework ontológico que quantifica a confiabilidade de sistemas computacionais a partir de quatro dimensões inter-relacionadas: segurança, confiança, resiliência e agilidade. As métricas são organizadas de forma hierárquica, e o modelo possui aplicação prática na avaliação de sistemas e no planejamento de estratégias baseadas no cálculo quantitativo de submétricas. Já o estudo **E4** realiza uma sistematização de frameworks ontológicos aplicáveis à família de normas ISO/IEC 27000. Além de recomendar ontologias específicas para cada norma, o estudo identifica lacunas relevantes para futuras pesquisas em modelagem de riscos, ampliando as possibilidades de aplicação da ontologia no contexto normativo. O estudo **E5** aborda frameworks especializados, destacando o D3FEND, voltado à definição de contramedidas de cibersegurança, e o IoTSec, projetado para a segurança em ambientes de Internet das Coisas (IoT) industriais. Este último apresenta uma estrutura ontológica robusta com 228 classes, cobrindo aspectos de segurança em ambientes operacionais críticos, o que o torna altamente relevante para setores industriais. No estudo **E7**, é proposto o sCuDO, um framework ontológico baseado na Teoria Multi-Nível e na Ontologia UFO. O objetivo é realizar a classificação de ataques por meio da integração de taxonomias consolidadas do domínio de segurança, oferecendo uma estrutura analítica capaz de representar múltiplos níveis de abstração em cenários de ataque. Avançando na direção da automação, o estudo **E9** propõe um método para a geração de ontologias genéricas a partir de dicionários especializados, resultando em uma estrutura ontológica com 2518 conceitos. Essa ontologia genérica pode ser reutilizada como base para o desenvolvimento de soluções específicas, acelerando o processo de construção ontológica. Por fim, os estudos **E15** (APKOWL) e **E13** complementam esse espectro com frameworks voltados à detecção de malware e à classificação de ontologias, respectivamente. O APKOWL aplica técnicas de engenharia reversa para construir ontologias a partir de aplicativos móveis, enquanto o estudo E13 foca na categorização e organização de ontologias de segurança. Juntos, esses estudos demonstram uma evolução contínua desde abordagens teóricas até aplicações práticas e automatizadas em segurança cibernética.

- **Ferramentas e Automação**: O estudo **E1** destaca o uso do editor de ontologias Protégé — desenvolvido pela Universidade de Stanford — como base para construção de uma ontologia de domínio de segurança alinhada à norma ISO. O estudo **E10** complementa essa abordagem, utilizando, além do Protégé, o yEd Graph Editor

Manual como ferramenta gráfica para visualização e manipulação de grafos ontológicos. O estudo **E12** apresenta um guia prático para construção de ontologias em OWL, empregando o Protégé 4 em conjunto com as ferramentas CO-ODE (Collaborative Ontology Design Environment) — um conjunto de plugins desenvolvidos pela Universidade de Manchester que facilitam a modelagem colaborativa de ontologias em OWL por meio de recursos avançados de edição e validação. No estudo **E13**, os autores implementam a ontologia CRATELO (Context-aware Rule-based Adaptive Trust framework for Edge and Fog Computing Environments using Logic-based Ontologies) em OWL e SWRL, utilizando o Protégé para permitir raciocínio automatizado sobre confiança em ambientes de Edge Computing. O estudo **E15** demonstra uma abordagem para detecção de malware que combina regras SWRL (Semantic Web Rule Language) com o motor de inferência Jess (Java Expert System Shell), permitindo a derivação automatizada de intenções maliciosas a partir de ontologias de segurança. Nesta abordagem, as regras SWRL capturam padrões comportamentais de malware, enquanto o Jess executa essas regras de forma eficiente para gerar conclusões. O estudo **E16** apresenta um sistema que gera automaticamente estratégias de ataque baseadas em múltiplas vulnerabilidades, utilizando um grafo de conhecimento de domínio que relaciona vulnerabilidades, exploits e alvos potenciais. O estudo **E17** apresenta o sistema VALARIN para análise automatizada de arquivos PDF, combinando um pipeline de processamento com múltiplos parsers especializados, uma ontologia OWL desenvolvida no *Protégé* para classificação de malware, e métodos semi-automatizados para geração e fusão de ontologias. Este sistema utiliza, na detecção de PDFs maliciosos, abordagens híbridas que integram: (i) automação no processamento por meio de parsers; (ii) avaliação baseada na ontologia principal construída no Protégé; e (iii) intervenção humana especializada para validação final e refinamento das ontologias secundárias. Essa arquitetura permite análise em larga escala, mantendo a precisão na classificação de ameaças, com a ontologia atuando como núcleo de conhecimento para decisões automatizadas e os especialistas garantindo a atualização contínua do sistema. Por sua vez, o estudo **E19** apresenta uma abordagem inovadora para o desenvolvimento automático de ontologias na área de segurança da informação, utilizando técnicas de Processamento de Linguagem Natural (PLN) para extração de conceitos a partir de corpora textuais. A metodologia emprega múltiplos algoritmos de mineração de conhecimento e integra o yEd Graph Editor para visualização e manipulação dos grafos ontológicos gerados. Essa solução oferece ganhos significativos de produtividade, permitindo que especialistas concentrem seus esforços na validação e refinamento das ontologias, em vez de sua construção manual. Como estudo de caso, os autores

demonstram a aplicação prática do modelo na criação automática de ontologias para detecção e isolamento de falhas em sistemas automotivos em cenários reais.

- **Padronização e Qualidade**: Os estudos analisados demonstram forte integração com normas internacionais, especialmente aquelas pertencentes à família ISO. O estudo **E1** apresenta a modelagem de uma ontologia de domínio de segurança baseada nas normas ISO/IEC 27000 e ISO/IEC 27001, estabelecendo uma estrutura formal alinhada às melhores práticas de gestão da segurança da informação. Complementarmente, o estudo **E2** aborda os fundamentos necessários para compreender a estrutura de métricas de qualidade de sistemas, referenciando as normas ISO/IEC 9126 e ISO/IEC 25000 no contexto da avaliação da qualidade de produtos de software. No mesmo escopo de padronização, o estudo **E4** apresenta um conjunto de recomendações para o uso de ontologias específicas associadas aos diferentes padrões da série ISO/IEC 27k, reforçando a importância da adaptação ontológica conforme cada norma. Avançando para uma aplicação prática, o estudo **E5** propõe e desenvolve a Rantology, uma ontologia dedicada à detecção de extorsões digitais. A lógica codificada nesta ontologia permite avaliar a maliciosidade de programas com base em múltiplos componentes, sendo que os resultados obtidos confirmam sua adequação segundo critérios consolidados de qualidade. O estudo **E10** descreve o processo de criação de ontologias com o apoio das metodologias Methontology e IDEF5, buscando garantir a estruturação e a qualidade do produto ontológico final. Em uma abordagem mais integradora, o estudo **E12** destaca a aplicação de múltiplas ontologias no escopo da norma ISO/IEC 27032, evidenciando seu papel essencial na padronização da interoperabilidade entre sistemas de segurança da informação. Por último, o estudo **E13** propõe um framework para a caracterização conceitual de ontologias voltadas à segurança cibernética, com o objetivo de oferecer uma base homogênea, clara e bem definida para a comparação entre diferentes ontologias e suas conceituações. Esse framework adere aos princípios *FAIR* (Findability, Accessibility, Interoperability, and Reuse) aplicáveis a ativos digitais, e apresenta um procedimento composto por cinco etapas, permitindo a classificação de ontologias de acordo com níveis ortogonais de categorização, assegurando maior consistência nas análises comparativas.

A **Tabela** 7 apresentada acima, compõem a síntese dos estudos Nna dimensão Tecnologia relacionados às respostas da Sub-Q1.

Tabela 7: Estudos na dimensão **Tecnologias** – categorizados por tipo de abordagem – relacionados às respostas da Sub-Q1.

Dimensão: Tecnologias		
Desenvolvimento de Frameworks		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Framework para SIEM baseado em ontologia dupla camada; ISO 27000, BFO, OWL	Desenvolvimento de Frameworks
E2	STRAM: métricas para segurança, confiança, resiliência e agilidade	Desenvolvimento de Frameworks
E4	Sistematização de frameworks para normas ISO/IEC 27000	Desenvolvimento de Frameworks
E5	Frameworks D3FEND (contramedidas) e IoTSec (IoT industrial)	Desenvolvimento de Frameworks
E7	sCuDO: classificação de ataques com Ontologia UFO	Desenvolvimento de Frameworks
E9	Geração automática de ontologias genéricas	Desenvolvimento de Frameworks
E13	Framework para caracterização e classificação de ontologias	Desenvolvimento de Frameworks
E15	APKOWL para construção automática a partir de apps móveis	Desenvolvimento de Frameworks
Ferramentas e Automação		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Protégé para construção ontológica alinhada à ISO	Ferramentas e Automação
E10	Protégé e yEd para visualização/manipulação de grafos	Ferramentas e Automação
E12	Protégé 4 + CO-ODE para modelagem colaborativa	Ferramentas e Automação
E13	CRATELO em OWL e SWRL para raciocínio automatizado em Edge Computing	Ferramentas e Automação
E15	Regras SWRL + Jess para detecção automatizada de intenções maliciosas	Ferramentas e Automação
E16	Gerador automático de estratégias de ataque via grafo de conhecimento	Ferramentas e Automação
E17	VALARIN: análise automática de PDFs usando ontologias, parsers e intervenção humana	Ferramentas e Automação
E19	PLN e mineração para extração de conceitos; visualização com yEd; aplicada a falhas automotivas	Ferramentas e Automação
Padronização e Qualidade		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Ontologia baseada nas normas ISO/IEC 27000 e ISO/IEC 27001	Padronização e Qualidade
E2	Normas ISO/IEC 9126 e 25000 para avaliação da qualidade de software	Padronização e Qualidade
E4	Recomenda ontologias para normas ISO/IEC 27k	Padronização e Qualidade
E5	Rantology para detecção de extorsões digitais com critérios de qualidade	Padronização e Qualidade
E10	Methontology e IDEF5 para criação estruturada de ontologias	Padronização e Qualidade
E12	Uso de múltiplas ontologias para interoperabilidade ISO/IEC 27032	Padronização e Qualidade
E13	Framework para classificação de ontologias baseado nos princípios FAIR	Padronização e Qualidade

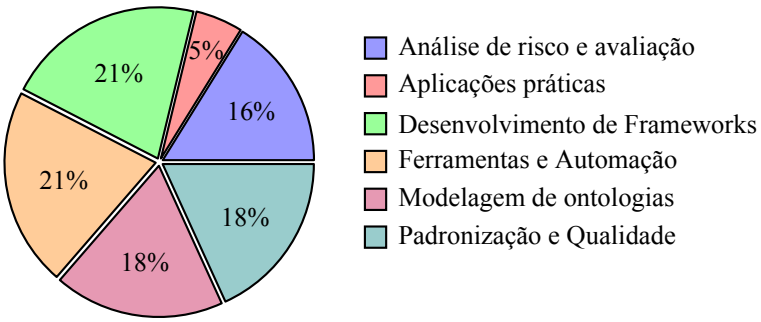


Figura 10: Distribuição percentual dos estudos por subcategoria.

A **Figura** 10 exibe a distribuição percentual dos estudos segundo as dimensões fundamentais de SI e suas subcategorias, identificadas na análise.

Tabela 8: Distribuição dos estudos pelas dimensões em SI e subcategorias identificadas nesta RSL.

Dimensão	**Subcategoria**	**Estudos**
Pessoas	Aplicações Práticas	E5, E8
Processos	Análise e Avaliação de Riscos	E1, E2, E4, E10, E11, E13, E18
	Modelagem de Ontologias	E1, E5, E8, E9, E10, E12, E15, E17
Tecnologias	Desenvolvimento de Frameworks	E1, E2, E4, E5, E7, E9, E13, E15
	Ferramentas e Automação	E1, E10, E12, E13, E15, E16, E17, E19
	-	E1, E2, E4, E5, E10, E12, E13

A **Tabela** 7, por sua vez, apresenta a distribuição dos estudos pelas dimensões em SI e as subcategorias identificadas identificadas neste RSL..

***Sub-Q2**: Como é avaliado o desempenho das ontologias de segurança, considerando as dimensões pessoas, processos e tecnologia em SI?*

A avaliação de desempenho de ontologias de segurança é condicionada por três componentes determinantes: (i) o conjunto de tecnologias empregadas, (ii) os objetivos específicos de cada implementação, e (iii) o contexto de aplicação. A análise dos estudos revisados permitiu categorizar sistematicamente as abordagens de avaliação segundo as dimensões clássicas de SI: **Pessoas**, **Processos** e **Tecnologias** (LAUDON; LAUDON, 2020).

Na dimensão **Pessoas**, predominam as **Avaliação de Usabilidade**, **Avaliação Qualitativa** e **Avaliação Profissional**, com foco em aplicação em cenários reais.

- **Avaliação de Usabilidade**: O estudo **E2** propõe o framework STRAM, que mede a confiabilidade de sistemas computacionais, levando em conta componentes humanos como usabilidade, *desempenho* e satisfação. Ele também destaca ferramentas de avaliação que envolvem a simulação de ataques por pessoas para identificar vulnerabilidades no sistema. O estudo **E18** detalha o desenvolvimento da IJPRA, uma ontologia voltada para aeroportos inteligentes, que foi avaliada por meio de cenários de análise de riscos de privacidade, com a realização de sessões de revisão para garantir a qualidade e relevância dos cenários, representando, assim, uma avaliação da usabilidade da ontologia. O estudo **E19** avalia conteúdo e usabilidade em cenários de ataques, analisando também desempenho na detecção de ameaças.

- **Avaliação Profissional**: No estudo **E12**, é proposta uma estrutura multi-ontológica para o modelo de ameaças de sistemas de informação (ISTMOF), sugerindo que essa estrutura pode orientar profissionais de segurança que exigem habilidades especializadas e prática contínua.

- **Avaliação Qualitativa**: O estudo **E5** descreve a ontologia Rantology voltada para ataques de ransomware. Tal ontologia é avaliada com base em critérios como clareza, modularidade, consistência e cobertura, sendo a clareza especialmente relevante para garantir a compreensão por parte dos usuários. O estudo **E6** propõe o uso de thesauri de tarefas baseados em ontologias para associar resultados de aprendizagem a descrições de tarefas no domínio da segurança da informação. A validação do processo de aprendizagem envolve a comparação de competências descritas em linguagem natural com descrições formalizadas, o que serve como uma forma prática de avaliar a aplicabilidade do conhecimento das pessoas. O estudo **E8**, por sua vez, aborda o desenvolvimento de uma ontologia para engenharia social, sugerindo que sua avaliação deve ser feita por meio de métodos de resolução de problemas ou aplicando-a em cenários de ataques de engenharia social, envolvendo a compreensão do comportamento humano em contextos de segurança.

A **Tabela 9** apresenta a distribuição dos estudos analisados na dimensão **Pessoas** relacionados às respostas da Sub-Q2.

Na dimensão **Processos**, as avaliações concentram-se em aspectos conceituais, estruturais e metodológicos das ontologias. Destacam-se **Análise ontológica e de desempenho**, **Metodologias de avaliação** e **Validação do desempenho em segurança**.

Tabela 9: Estudos na dimensão **Pessoas** — Avaliações de Usabilidade, Qualitativa e Profissional relacionadas às respostas da Sub-Q2.

Dimensão: Pessoas		
Avaliação de Usabilidade		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Questionários aplicados a usuários finais para avaliar facilidade de uso	Avaliação de Usabilidade
E2	Estudo de caso com feedback de usuários quanto à experiência de uso	Avaliação de Usabilidade
E3	Testes de usabilidade com foco em eficiência e satisfação dos usuários	Avaliação de Usabilidade
E4	Análise heurística com especialistas em interação humano-computador	Avaliação de Usabilidade
E7	Entrevistas com participantes após uso de protótipos ontológicos	Avaliação de Usabilidade
E9	Observações e coleta de métricas durante a interação com a ontologia	Avaliação de Usabilidade
E11	Análise de usabilidade com base em tarefas realizadas por usuários	Avaliação de Usabilidade
Avaliação Qualitativa		
Estudo	**Técnica Utilizada**	**Tipo**
E5	Avaliação baseada em clareza, modularidade, consistência e cobertura	Avaliação Qualitativa
E6	Validação de tarefas com linguagem natural versus formalizada	Avaliação Qualitativa
E8	Avaliação por resolução de problemas em cenários de engenharia social	Avaliação Qualitativa
Avaliação Profissional		
Estudo	**Técnica Utilizada**	**Tipo**
E12	Orientação prática para profissionais com habilidades especializadas	Avaliação Profissional

- **Análise ontológica e de desempenho:**: o estudo **E1** explora o uso de ontologias para modelar padrões de segurança, como a ISO/IEC 27001 e 27002, com o objetivo de formalizar o conhecimento e apoiar a análise e otimização dos processos de gestão da segurança da informação. Além disso, é introduzida uma ontologia baseada na ISO, utilizando o BFO para promover a interoperabilidade entre diferentes domínios. O estudo **E2** propõe a estrutura STRAM, composta por sub-ontologias para segurança, confiança, resiliência e agilidade, com o intuito de formalizar e avaliar o desempenho de sistemas em diversas dimensões, utilizando abordagens de modelagem, análise e experimentação. No mesmo contexto, o estudo **E5** apresenta uma ontologia voltada para o domínio de ransomware, evidenciando como a modelagem ontológica pode contribuir para o entendimento e mitigação de impactos em processos de sistemas de informação. Já o estudo **E6** propõe o uso de ontologias para estruturar conhecimentos de aprendizagem não formal e informal na área de segurança da informação, contribuindo para a descrição e análise dos processos de SI. Também se destaca o estudo **E7**, que desenvolve a ontologia *sCuDO*, baseada na Teoria Multinível (MLT) e na Ontologia Fundacional Unificada (UFO), com o objetivo de modelar incidentes de segurança da informação, tornar os conceitos mais explícitos e apoiar a gestão de processos de incidentes. O estudo **E10** discute metodologias para o desenvolvimento de ontologias aplicáveis à segurança da informação, ressaltando a importância da formalização explícita para o suporte a processos e sistemas baseados em conhecimento. O estudo **E12** apresenta uma estrutura multi-ontológica, composta pela ISTGO, ISTDO e ISTAO, para modelagem de ameaças em sistemas de informação, aplicando análise ontológica para resolver problemas de ambiguidade e incompletude nos processos de segurança. Por fim, o estudo **E18** utiliza o modelo *AttTucker*, adotando métricas como *F1-score* e precisão para mensurar a qualidade dos grafos de conhecimento, evidenciando o impacto da análise de caminhos entre entidades no desempenho de processos relacionados à segurança da informação.

- **Metodologias de avaliação:** o estudo **E2** propõe a estrutura de métricas baseada em ontologia (STRAM) para medir a *trustworthiness* de sistemas. Esta abordagem inclui atributos fundamentais como segurança, confiança, resiliência e agilidade. O estudo classifica os métodos de medição em dois tipos principais: os baseados em modelagem/análise (tais como modelos estocásticos e simulação) e os baseados em experimentos, proporcionando uma metodologia robusta para avaliar diversos aspectos dos processos de SI. Em sequência, o estudo **E4** discute a certificação ISO/IEC 27001, com ênfase no processo de auditoria e avaliação da conformidade dos processos de gestão da segurança da informação com os requisitos da norma.

Além disso, o estudo utiliza métricas para o mapeamento de padrões de segurança baseados em ontologia. No que se refere à

- **Validação do desempenho em segurança**: o estudo **E4** analisa riscos com base em táticas, técnicas, vulnerabilidades e probabilidades de sucesso de ataques. O estudo **E7** aplica estudos de caso para validar o framework multiontologia ISTMOF, voltado à modelagem de ameaças. Complementando esse contexto, o estudo **E8** realiza uma revisão sistemática de métricas, com foco na aplicabilidade de submétricas de segurança. O estudo **E12** adota um processo iterativo de refinamento contínuo, utilizando cenários ilustrativos para testar a aplicabilidade da ontologia. Também, o estudo **E13** apresenta um *framework* para a classificação de ontologias, oferecendo uma abordagem metodológica para analisar o estado das ontologias no domínio da segurança da informação. Essa ferramenta se mostra útil também na avaliação da formalização e da estrutura dos processos de SI. Por fim, o estudo **E14** valida a ontologia *sCuDO* com dados reais, demonstrando sua aplicabilidade e robustez em comparação com abordagens não ontológicas.

Na dimensão **Tecnologias**, destacam-se as seguintes categorias: **Avaliações quantitativas com métricas de desempenho** e **Validações baseadas em critérios de qualidade**.

- **Avaliações quantitativas com métricas de desempenho**: o estudo **E2** propõe o framework STRAM para medir a qualidade de sistemas computacionais, considerando diversos aspectos tecnológicos e **métricas de desempenho** para avaliar ferramentas de avaliação. O estudo **E5** descreve o desenvolvimento e a avaliação da Rantology, uma ontologia para ataques de ransomware. A avaliação envolve diferentes abordagens, incluindo a comparação com um padrão de ouro, com uma fonte de dados, o uso em uma aplicação e a avaliação manual por especialistas. A qualidade da Rantology também é medida com base em **métricas de esquema** fornecidas pelo OntoQA. A capacidade de raciocínio da ontologia é testada para verificar a **subsunção** e a **consistência**, e a sua capacidade de responder a questões de competência é também avaliada. O estudo **E8** afirma que a melhor forma de avaliar a qualidade de uma ontologia desenvolvida é por meio de **métodos de resolução de problemas** ou utilizando-a em **aplicações reais**. A ontologia de engenharia social é avaliada por meio da sua aplicação na análise de cenários de ataques.

- **Validações baseadas em critérios de qualidade**: o estudo **E2** considera atributos como **consistência**, **completude**, **usabilidade**, **testes de implementação** e **feedback de especialistas**. O estudo **E3** aplica critérios de **completude**, **validade** e **aplicabilidade**, alinhando-se a revisões sistemáticas. O estudo **E10** avalia a inte-

Tabela 10: Avaliações dos estudos segundo a dimensão **Processos**, por tipo de avaliação

Dimensão: Processos		
Análise Ontológica e de Desempenho		
Estudo	**Técnica Utilizada**	**Tipo de Avaliação**
E1	Uso de ontologias para modelar padrões de segurança ISO/IEC 27001 e 27002, com ontologia baseada em BFO para interoperabilidade entre domínios	Análise ontológica e de desempenho
E2	Estrutura STRAM com sub-ontologias para segurança, confiança, resiliência e agilidade, para avaliação do desempenho de sistemas em múltiplas dimensões	Análise ontológica e de desempenho
E5	Ontologia para domínio ransomware, contribuindo para entendimento e mitigação de impactos nos processos de SI	Análise ontológica e de desempenho
E6	Ontologias para estruturar conhecimentos de aprendizagem não formal e informal na segurança da informação, analisando processos de SI	Análise ontológica e de desempenho
E7	Ontologia *sCuDO* baseada em MLT e UFO para modelagem de incidentes de segurança e apoio à gestão de processos	Análise ontológica e de desempenho
E10	Metodologias para desenvolvimento de ontologias para segurança da informação, destacando a formalização para suporte a processos e sistemas	Análise ontológica e de desempenho
E12	Estrutura multi-ontológica ISTGO, ISTDO e ISTAO para modelagem de ameaças, resolvendo ambiguidade e incompletude nos processos de segurança	Análise ontológica e de desempenho
E18	Uso do modelo *AttTucker* com métricas *F1-score* e precisão para avaliar qualidade de grafos e impacto na análise de processos de segurança	Análise ontológica e de desempenho
Metodologias de Avaliação		
Estudo	**Técnica Utilizada**	**Tipo de Avaliação**
E2	Estrutura STRAM para medir *trustworthiness* com métodos de modelagem/análise e experimentação em processos de SI	Metodologia de avaliação
E4	Auditoria e certificação ISO/IEC 27001, com métricas para avaliação da conformidade e mapeamento de padrões ontológicos	Metodologia de avaliação
Validação do Desempenho em Segurança		
Estudo	**Técnica Utilizada**	**Tipo de Avaliação**
E4	Análise de riscos baseada em táticas, técnicas, vulnerabilidades e probabilidade de ataques para processos críticos	Validação do desempenho em segurança
E7	Estudos de caso para validar framework multi-ontologia ISTMOF em contextos organizacionais de gestão de processos	Validação do desempenho em segurança
E8	Revisão sistemática de métricas de segurança da informação, com foco em submétricas e indicadores aplicáveis a processos	Validação do desempenho em segurança
E12	Processo iterativo com cenários ilustrativos para testar a aplicabilidade prática da ontologia em ambientes reais	Validação do desempenho em segurança
E13	Desenvolvimento de framework para classificação e categorização de ontologias para modelagem de processos em SI	Validação do desempenho em segurança
E14	Validação experimental da ontologia *sCuDO* com dados reais, comparando desempenho com abordagens tradicionais	Validação do desempenho em segurança

gração da ontologia com **normas ISO/IEC 27000** e sua **cobertura conceitual**. O estudo **E15** valida o framework em contextos comerciais (Accenture LTD), comparando **abordagens manuais e automatizadas** com base em **esforço**, **tempo** e **custo**.

Tabela 11: Avaliações dos estudos segundo a dimensão **Tecnologias**, por tipo de avaliação

Dimensão: Tecnologias		
Avaliações quantitativas com métricas de desempenho		
Estudo	**Técnica Utilizada**	**Tipo de Avaliação**
E2	Aplicação de métricas de desempenho para avaliar a eficiência da ontologia em testes de implementação; análise qualitativa com base no feedback de especialistas	Avaliação Quantitativa
E5	Emprego de métricas estruturais como OntoQA para avaliar a completude, coerência e coesão da ontologia; testes de subsunção lógica e verificação de consistência ontológica	Avaliação Técnica
E8	Implementação prática da ontologia em cenários simulados de ataques cibernéticos, avaliando sua efetividade na detecção e resposta a incidentes	Validação Tecnológica
Validações baseadas em critérios de qualidade		
Estudo	**Técnica Utilizada**	**Tipo de Avaliação**
E2	Avaliação de critérios de qualidade como consistência, completude e usabilidade da ontologia, com base na opinião de especialistas da área técnica	Avaliação de Qualidade
E3	Análise conceitual da ontologia por meio de critérios como completude de domínio, validade dos conceitos e aplicabilidade em ambientes reais de TI	Avaliação Conceitual
E10	Integração da ontologia com normas de segurança da informação (ISO/IEC 27000), avaliando a aderência, interoperabilidade e cobertura conceitual	Avaliação de Integração
E15	Comparação entre abordagens manuais e automatizadas na construção de ontologias, avaliando esforço requerido, tempo de execução e custos envolvidos	Avaliação Comparativa

Dessa forma, observa-se que a avaliação das ontologias de segurança em SI é multidimensional, sendo conduzida com base na natureza da proposta e alinhando-se às dimensões de Processos, Pessoas e Tecnologias. As abordagens vão desde análises conceituais e estruturais até testes empíricos e métricas quantitativas, refletindo a complexidade e a diversidade dos contextos de aplicação.

E na **Figura 11**, é apresentada a distribuição percentual dos estudos segundo os métodos de avaliação nas dimensões de SI.

Tabela 12: Distribuição dos estudos nas dimensões fundamentais em Sistemas de Informação (SI) e pelas subcategorias identificadas nos estudos analisados (corrigida).

Dimensão de SI	Subcategoria	Estudos
Pessoas	Avaliação de Usabilidade	E1, E2, E3, E4, E7, E9, E11
	Avaliação Profissional	E12
	Avaliação Qualitativa	E5, E6, E8
Processos	Metodologias de avaliação	E2, E4
	Validação do desempenho em segurança	E4, E7, E8, E12, E13, E14
Tecnologias	Avaliações Quantitativas com Métricas de Desempenho	E2, E5
	Validações Baseadas em Critérios de Qualidade	E2, E3, E8, E10, E15

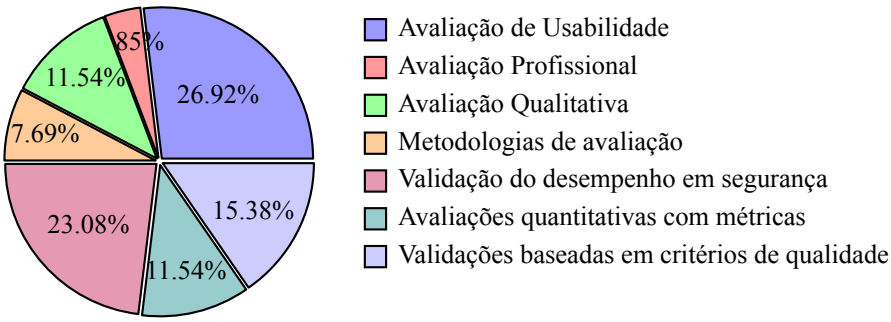


Figura 11: Distribuição percentual dos estudos por subcategorias nas dimensões fundamentais de Sistemas de Informação (SI).

Sub-Q3:*Quais componentes impactam o desenvolvimento e a aplicação das ontologias de segurança em cada uma das dimensões de SI?*

Esta questão teve como objetivo identificar os componentes das ontologias de segurança que apresentam aderência às normas e melhores práticas reconhecidas, bem como sua capacidade de integração com outros padrões e sistemas em SI (SZYPERSKI, 2002)(SOMMERVILLE, 2016a). Nos estudos analisados, destacaram-se diversos componentes principais: **Normas e Integração de Ontologias, Avaliação de Riscos e Ameaças, Aspectos Técnicos de Implementação e Aspectos Humanos e Comportamentais**.

Os componentes podem ser agrupados de acordo com as dimensões em Sistemas de Informação: **Pessoas**, **Processos** e **Tecnologias**.

Na dimensão Pessoas, os componentes **Aspectos Humanos e Comportamentais** referem-se ao impacto do comportamento humano e dos fatores sociais sobre a segurança nos SI.

- **Aspectos Humanos e Comportamentais:** O **estudo E2** apresenta o framework

STRAM, desenvolvido para mensurar a confiabilidade de sistemas de segurança por meio de uma estrutura baseada em ontologias. Embora o foco principal esteja na modelagem da arquitetura do sistema e nas métricas associadas, o estudo reconhece a relevância da dimensão humana ao incorporar os "fatores humanos" como um dos componentes a serem avaliados. Além disso, faz referência a estudos prévios que modelam aspectos comportamentais, como o impacto de traços de personalidade na confiança e na suscetibilidade a ataques de *phishing*, evidenciando a importância da representação técnica desses elementos no domínio da segurança cibernética. O **estudo E5** também ressalta a relevância dos aspectos humanos e comportamentais, incluindo a conscientização situacional e o papel do comportamento do usuário na gestão de riscos e na segurança. A ontologia desenvolvida incorpora explicitamente a dimensão "Pessoas", por meio de classes como *Atacante* e *Vítima*, além de discutir como esses fatores são essenciais para uma compreensão abrangente da segurança cibernética no contexto ontológico. O **estudo E7** aborda a classificação e priorização de incidentes com base no impacto organizacional e no comportamento dos participantes. A ontologia proposta organiza os incidentes de segurança de maneira a priorizar aqueles com maior impacto, considerando as ações humanas envolvidas em sua ocorrência. Por fim, o **estudo E8** dedica-se integralmente à construção de uma ontologia de domínio voltada à engenharia social, com ênfase na modelagem e categorização de vulnerabilidades humanas — elementos centrais nesse tipo de ataque. Tais vulnerabilidades são descritas em dimensões como cognição/conhecimento, comportamento/hábito, emoção/sentimento e aspectos psicológicos, incluindo traços de personalidade, natureza humana e caráter individual. O estudo destaca a influência crítica de fatores humanos, como comportamentos suscetíveis e julgamentos equivocados, que podem ser explorados por agentes maliciosos em campanhas de engenharia social. A ontologia desenvolvida contempla esses componentes humanos, definindo formalmente conceitos, classes e relações semânticas que permitem representar tais aspectos de maneira estruturada, promovendo uma abordagem sistemática à dimensão "Pessoas" no contexto da segurança da informação.

Na dimensão Processos, tem-se o componente **Avaliação de Riscos e Ameaças**, cujo foco está na identificação, análise e mitigação dos riscos e ameaças à segurança em SI, considerando tanto os aspectos técnicos quanto os humanos.

- **Avaliação de Riscos e Ameaças:** o estudo **E1** aborda auditoria e certificação e o uso de ontologias de segurança para apoiar a certificação ISO/IEC 27001. Também explora o mapeamento de padrões de segurança, como a ISO 27002, para estru-

turas ontológicas. No estudo **E2**, é abordada a avaliação de interconexões entre diferentes componentes de segurança e os riscos associados. A ontologia permite mapear as interações entre vulnerabilidades, ameaças e defesas, o que é fundamental para avaliar a segurança de forma holística e identificar pontos críticos de falha. No estudo **E3**, destaca-se o uso de fontes internas e externas de dados para uma visão holística do risco cibernético. A ontologia deve integrar dados provenientes de diversas fontes internas e externas para proporcionar uma análise mais precisa e abrangente dos riscos cibernéticos. No estudo **E10**, é abordada a abordagem de causas e consequências de riscos de segurança e ameaças. O modelo de ontologia mapeia os riscos e suas consequências, considerando as relações entre os diferentes componentes de segurança. Isso permite uma visão detalhada de como as ameaças podem impactar os sistemas. O estudo **E11** foca na identificação de componentes de ataque, risco e requisitos de segurança para ataques APT. A ontologia considera as táticas, técnicas e procedimentos (TTPs) de ataques avançados (APT), além de avaliar as vulnerabilidades e as medidas de segurança necessárias para mitigar esses riscos. O estudo **E13** é dedicado à caracterização e classificação de ontologias no domínio da cibersegurança. Ele inclui e discute de forma explícita a *Common Ontology of Value and Risk* (COoVR) e a ontologia da norma ISO/IEC 27005:2011, sendo esta última uma norma específica para a gestão de riscos da segurança da informação. O documento realiza uma análise ontológica aprofundada dos conceitos de *Risco* e *Avaliação de Risco*, discutindo como as ontologias podem ser utilizadas para modelar o domínio de valor e risco, bem como os processos de gestão de riscos. O estudo **E14** apresenta o desenvolvimento de uma ontologia chamada **ContSOnto**, baseada na norma ISO 13940 para apoiar a continuidade do cuidado em sistemas de saúde. A ontologia visa garantir fluxos de estudo de dados seguros e confiáveis, promovendo a integridade e a consistência das informações ao longo do processo de cuidado. O estudo **E15** concentra-se no processo de detecção de ransomware no nível de design, por meio da ontologia **APKOWL**, construída a partir da engenharia reversa de aplicativos móveis. O processo envolve a modelagem da estrutura e do comportamento do malware, simulando suas interações com o sistema, como chamadas de API. Essa análise detalhada do processo de execução da ameaça permite sua identificação e mitigação, além de possibilitar o reconhecimento de malware APT com base em representações ontológicas. O estudo **E18** trata da avaliação de riscos relacionados à privacidade em ambientes de aeroportos inteligentes. A ontologia ajuda a analisar os riscos de privacidade associados ao uso de tecnologias em aeroportos, com foco na proteção de dados pessoais dos passageiros. Por fim, o estudo **E19** analisa a qualidade dos dados e conflitos em grafos de conhecimento

de cibersegurança. A ontologia deve avaliar a qualidade dos dados utilizados na construção de grafos de conhecimento, levando em conta a presença de ruídos ou conflitos que possam afetar a precisão das análises de segurança.

Tabela 13: Estudos relacionados às respostas da Sub-Q3, organizados por dimensão (**Pessoas** e **Processos**).

Dimensão: Pessoas		
Aspectos Humanos e Comportamentais		
Estudo	**Técnica Utilizada**	**Tipo**
E2	Framework STRAM que incorpora fatores humanos na avaliação de confiabilidade	Modelagem ontológica com referência a fatores comportamentais
E5	Ontologia com classes como Atacante e Vítima para representar comportamento humano	Modelagem ontológica com ênfase em usuários
E7	Ontologia para classificação e priorização de incidentes com base em impacto humano	Análise de incidentes e ações humanas
E8	Ontologia de engenharia social com categorias cognitivas, comportamentais e emocionais	Modelagem ontológica de vulnerabilidades humanas
Avaliação de Riscos e Ameaças		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Mapeamento ontológico da ISO/IEC 27001 e ISO 27002	Modelagem normativa ontológica
E2	Avaliação de interações entre vulnerabilidades, ameaças e defesas	Mapeamento ontológico de riscos
E3	Integração de dados internos e externos para avaliação de risco cibernético	Modelagem de riscos com dados heterogêneos
E10	Mapeamento de causas e consequências de riscos e ameaças	Ontologia de análise de impacto
E11	Modelagem de TTPs de ataques APT e requisitos de segurança	Ontologia de ataques avançados (APT)
E13	COoVR e ISO/IEC 27005 para modelagem do domínio de risco	Ontologias de risco e valor
E14	Ontologia baseada na ISO 13940 para segurança na continuidade do cuidado em saúde	Modelagem ontológica de processos de saúde
E15	Ontologia APKOWL para detecção de ransomware via engenharia reversa	Modelagem do ciclo de ameaças
E18	Ontologia IJPRA para análise de riscos de privacidade em aeroportos inteligentes	Modelagem ontológica de privacidade
E19	Avaliação de qualidade e conflitos em grafos de conhecimento de cibersegurança	Análise ontológica de dados de segurança

Na dimensão **Tecnologias**, destacam-se dois componentes principais: os *Aspectos Técnicos de Implementação*, que envolvem os métodos, ferramentas e linguagens usados na construção e aplicação de ontologias de segurança; e as *Normas e Integração de Ontologias*, que tratam da conformidade com padrões e da interoperabilidade com outros sistemas e ontologias.

- **Aspectos Técnicos de Implementação:** o estudo **E1** propõe o uso de ontologias como um instrumento poderoso para que computadores não apenas armazenem ou recuperem informações, mas também sejam capazes de interpretá-las. A abordagem consiste em modelar padrões específicos por meio de uma estrutura ontológica, permitindo que os sistemas computacionais atuem como consumidores ativos de informação. A representação de padrões particulares é tratada através de ontologias de domínio em um nível mais detalhado. As terminologias utilizadas buscam con-

formidade com padrões estabelecidos por organizações como o *National Institute of Standards and Technology* (NIST) e a ISO, que promovem a ordenação do conhecimento técnico-científico em nível conceitual, servindo como base para a modelagem técnica. O software *Protégé* é citado como uma ferramenta relevante nesse contexto. O estudo **E2** apresenta o framework *STRAM*, voltado à medição da confiabilidade de sistemas computacionais, com base em uma estrutura hierárquica de ontologias. Cada submétrica—Segurança, Confiança, Resiliência e Agilidade—é representada como uma subontologia. As ontologias formais são codificadas em linguagens legíveis por máquina, como a *Web Ontology Language* (OWL), formando assim ontologias computacionais. A ferramenta *Protégé* foi empregada no desenvolvimento da ontologia proposta. As medições podem ser realizadas com base em modelagem e análise, utilizando métodos como modelos estocásticos, simulação e emulação, ou por meio de experimentos. O framework propõe a inclusão de métricas relacionadas a ferramentas-chave de avaliação, como análise de vulnerabilidades, análise de risco e *Red Teaming*, reforçando a importância de métodos e ferramentas de avaliação. O estudo **E3** adota uma perspectiva tecnológica, envolvendo a construção de modelos e algoritmos com base ontológica. São enfatizadas decisões arquiteturais e tecnológicas no desenvolvimento de um sistema complexo, com implementação da ontologia integrada à base de conhecimento. A linguagem *SPARQL* é utilizada para formalização de consultas, destacando-se por seu alto grau de maturidade e versatilidade. Também é proposto o desenvolvimento de um pacote de software para gerenciamento de riscos e prevenção de ameaças. Além disso, é descrito um método técnico para identificação de usuários com base em padrões de interação na internet. O estudo **E4** realiza uma comparação entre ontologias com base em critérios como linguagem e ferramentas de desenvolvimento, destacando implementações em OWL, RDF e DAML. A análise considera características formais (*ABox*) e conceituais (*TBox*), níveis de axiomatização e a expressividade da linguagem adotada. Ontologias baseadas em normas ISO 27001, 27002 e 27005 são apresentadas como exemplos práticos de formalização normativa. O estudo **E5** descreve a aplicação de ontologias na análise de *malware*, utilizando DAML+OIL e o sistema de raciocínio DAMLJessKB. O framework ontológico emprega *machine learning* para examinar redes complexas de relações. Termos são extraídos de arquivos *manifest* de aplicativos, e representações semânticas são construídas com auxílio da UCO Ontology e bases como DBpedia e YAGO. Os dados são armazenados em triplas RDF. A ontologia é implementada em OWL, com definição de classes, propriedades e instâncias. O raciocinador *FaCT++* é usado para verificar subsunção e consistência. O Protégé permite consultas via *Description Logic*. A avaliação da ontologia baseia-se em

comparação com padrões de referência e uso prático, sendo adotados frameworks como o OntoQA. O estudo **E6** busca formalizar o conhecimento em cibersegurança por meio de ontologias, visando sua legibilidade por máquinas, automação de operações e intercâmbio eficiente de informações. Propõe-se o uso de tesauros baseados em ontologias para integração e correspondência entre domínios. A semântica de recursos como a Wikipédia é processada via análise ontológica, com geração automática de representações. As tecnologias da Web Semântica são referenciadas como essenciais para o acesso baseado em conhecimento. O estudo **E7** aplica ontologias em modelos conceituais para incidentes de segurança da informação. São discutidas representações em nível de instância e tipologias, com uso da *Unified Foundational Ontology* (UFO), abrangendo aspectos estruturais (UFO-A), temporais (UFO-B) e sociais (UFO-C). A linguagem SPARQL é mencionada para consultas semânticas. O estudo **E8** descreve a construção de uma ontologia no domínio da engenharia social, utilizando o método de Noy e McGuinness com adaptações. O Protégé 5.5.0 foi a ferramenta empregada. Classes e propriedades são modeladas com uso de *Description Logic*, incluindo a categorização de ataques.O estudo **E9** aborda a geração automática de ontologias a partir de fontes de dados textuais, destacando a economia de tempo e esforço. Métodos como *clustering* (MARCOV, *Fuzzy c-means*) e técnicas de Processamento de Linguagem Natural (NLP) são utilizados para extrair conceitos e atributos. O estudo **E10** trata da Ontologia de Segurança Combinada (CSO), cuja formalização foi realizada por meio de diagramas UML. A metodologia Methontology foi aplicada, incluindo etapas como especificação, conceituação, formalização, integração e implementação, combinada com outro método para facilitar o reuso. O estudo **E12** apresenta um framework de multiontologia (GO, DO, AO), construído com seleção ponderada de conceitos e mapeamentos entre classes. A proposta serve como guia técnico em atividades como testes de penetração e análise de ameaças. Diagramas UML são utilizados para modelagem conceitual. O estudo **E13** investiga a aplicação de *Knowledge Graphs* (KGs) como ontologias operacionais. Destacam-se decisões de projeto, linguagem e metodologia de implementação como determinantes na expressividade e axiomatização. A Metodologia Design Science é aplicada. O estudo propõe uma solução de *backend* para facilitar a análise cruzada e classificação de dados. O estudo **E14** descreve o sistema APKOWL, voltado à detecção automática de *malware* em nível de design, baseado em engenharia reversa de aplicativos móveis. A ontologia OWL é construída automaticamente em Python e Protégé. A implementação foi realizada em PyCharm e Google Colab, sendo avaliada por métricas como acurácia, precisão e *recall*. O estudo **E16** aborda o uso de ontologias e *Knowledge Graphs* em cibersegurança, com

aplicações em áreas como forense digital. Representações gráficas e mapeamento ontológico são utilizados para análise, com a ferramenta Neo4j-D3-VKG sendo referenciada. O estudo **E18** trata do desenvolvimento da ontologia IJPRA por meio da integração de outras ontologias. A modelagem gráfica é usada na representação de conceitos e relacionamentos. O banco de dados de grafo Neo4j é especificado para representar instâncias ontológicas.

- **Normas e Integração de Ontologias e Aspecto Técnicos de Implementação:** O estudo **E1** destaca a utilização de uma abordagem ontológica de dupla camada para modelar Sistemas de Gestão de Segurança da Informação (SIEMs), visando aprimorar tanto a segurança quanto a conformidade com normas, como a ISO 27000. A camada superior adota a *Basic Formal Ontology* (BFO), promovendo a interoperabilidade entre diferentes domínios, enquanto a camada específica modela detalhadamente as normas ISO. O principal objetivo é otimizar a gestão do ciclo de vida de documentos e práticas de segurança da informação, facilitando auditorias e certificações, como a ISO/IEC 27001.No estudo **E2**, é apresentada uma revisão e comparação das ontologias de segurança baseadas na série de normas ISO/IEC 27000, destacando o uso da tecnologia ontológica como uma ferramenta eficaz para vincular conceitos de segurança às normas. A análise leva em consideração diversos aspectos, como a integração com outras normas, as metodologias adotadas, as linguagens utilizadas e as lacunas conceituais presentes nas ontologias. O estudo **E7** descreve a criação de um fragmento de ontologia de domínio sobre incidentes de segurança da informação, utilizando a *Unified Foundational Ontology* (UFO) e a *Multi-Level Theory* (MLT). Este estudo visa aprimorar a clareza conceitual e a interoperabilidade. A MLT complementa a UFO ao permitir a definição de relações entre diferentes níveis de classificação, enquanto a UFO fornece uma base sólida e formalmente estruturada para representar conceitos do mundo real. A combinação UFO-MLT estabelece padrões úteis para o desenvolvimento de ontologias empresariais específicas, funcionando como uma base conceitual robusta. O estudo **E10** aborda os desafios enfrentados no alinhamento e comparação de ontologias, como a incompletude e as diferenças de modelagem entre domínios. Para superar essas limitações, foi proposta a **CSO** (Ontologia de Segurança Combinada), baseada na UFO, com o objetivo de unificar terminologias e facilitar a interoperabilidade entre os domínios de segurança da informação e segurança física. A CSO foi mapeada para diversas normas de segurança, como ISO/IEC 27001, NIST e PCI DSS, com o intuito de reduzir a complexidade, apoiar a gestão e aprimorar a tomada de decisões. O estudo **E10** também apresenta um framework de *modelagem de ameaças baseado em múltiplas ontologias*, visando resolver problemas comuns nos métodos

existentes, como ambiguidade, heterogeneidade, incompletude e fragmentação de modelos em diferentes níveis de abstração. O framework é composto por três camadas: uma *ontologia generalizada* (GO), uma *ontologia de domínio* (DO) e uma *ontologia de aplicação* (AO), todas baseadas em padrões como *ISO/IEC 27032* e *MITRE ATT&CK*. O estudo **E13** propõe um **Framework para Classificação de Ontologias** com foco na cibersegurança, fundamentado em princípios ontológicos que visam melhorar a **interoperabilidade semântica** entre diferentes modelos. O framework aborda a importância do *Compromisso Ontológico* para clarificar o significado dos construtos em linguagens de modelagem e contribuir para atingir os princípios **FAIR** (*Findability, Accessibility, Interoperability, and Reuse*) de ativos digitais. Esse modelo classifica ontologias de acordo com seu nível (ontologias fundamentais e de domínio) e aplicação (ontologias referenciais e operacionais), proporcionando uma base homogênea para comparações. Além disso, o framework considera a **validação e verificação terminológica** com base em normas reconhecidas, como ISO/IEC 27032 e 27000, estendendo e padronizando vocabulários. A análise das **relações entre ontologias** permite identificar subontologias, sobreposição de domínios e o uso de ontologias fundamentais comuns. A análise cruzada do conceito de "Risco" revela que diferentes ontologias (como SECCO, COoVR e a baseada na ISO/IEC 27005) apresentam divergências conceituais, evidenciando que **a interoperabilidade não pode ser garantida apenas por similaridade estrutural**, sendo necessária uma compreensão ontológica profunda. O estudo enfatiza que **a ambiguidade e a complexidade do domínio da cibersegurança exigem uma fundamentação ontológica robusta** para possibilitar a integração e reutilização eficaz do conhecimento. Por fim, o estudo **E18** apresenta a ontologia IJPRA (Integrated Interaction Journey and Privacy Risk Assessment), que integra as ontologias IJ (Interaction Journey) e PR (Privacy Risk), utilizando a norma NIST 800-30 como base para a integração. A ontologia IJPRA relaciona o processo de avaliação de risco de privacidade com ativos, riscos de privacidade, requisitos e controles, mapeando esses conceitos para os da UFO.

Tabela 14: Estudos na dimensão **Tecnologias** — Aspectos Técnicos de Implementação e Normas e Integração de Ontologias relacionados às respostas da Sub-Q3.

Dimensão: Tecnologias		
Aspectos Técnicos de Implementação		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Protégé, ontologias de domínio, modelagem ISO/NIST	Ferramenta e padrões
E2	Framework STRAM em OWL, simulação e emulação, Protégé	Ontologia computacional com métricas
E3	Ontologia integrada, SPARQL, pacote de software	Algoritmos ontológicos e consultas semânticas
E4	Comparação de OWL, RDF, DAML; TBox e ABox	Avaliação de linguagens ontológicas
E5	DAMLJessKB, machine learning, UCO Ontology, DBpedia	Raciocínio semântico com ontologias
E6	Ontologias legíveis por máquina, Wikipedia, tesauros	Web semântica e integração
E7	UFO-A/B/C, SPARQL, instâncias e tipologias	Ontologia de incidentes com fundamento formal
E8	Protégé 5.5.0, Description Logic	Ontologia formal de engenharia social
E9	Geração automática com NLP, clustering	Extração ontológica de textos
E10	UML, Methontology, integração de ontologias	Modelagem conceitual e formalização
E12	Multi-ontologia (GO, DO, AO), UML	Framework técnico para segurança
E13	Knowledge Graphs, Design Science, backend analítico	KG como ontologias operacionais
E14	APKOWL em Python/Protégé, métricas de avaliação	Implementação automatizada de ontologias
E16	Neo4j-D3-VKG, mapeamento ontológico gráfico	Ontologias em grafos de conhecimento
E18	Integração de ontologias, Neo4j, modelagem gráfica	Ontologia visual em banco de grafos
Normas e Integração de Ontologias		
Estudo	**Técnica Utilizada**	**Tipo**
E1	Ontologia de dupla camada com BFO e ISO 27000	Integração normativa e interoperabilidade
E2	Revisão de ontologias baseadas na série ISO/IEC 27000	Análise comparativa de conformidade
E7	Uso combinado de UFO e mapeamento de incidentes com fundamentação ontológica	Integração de ontologias e raciocínio semântico

Na **Tabela 15**, são apresentados a distribuição dos estudos pelas dimensões fundamentais em SI e subcategorias identificadas nos estudos analisados.

Tabela 15: Distribuição dos estudos nas dimensões fundamentais em SI e pelas subcategorias identificadas nos estudos analisados

Dimensão de SI	Subcategoria	Estudos
Pessoas	Aspectos Humanos e Comportamentais	E2, E5, E7, E8
Processos	Avaliação de Riscos e Ameaças	E1, E2, E3, E10, E11, E13, E14, E15, E18, E19
Tecnologias	Aspectos Técnicos de Implementação	E1, E2, E3, E4, E5, E6, E7, E8, E9, E10, E12, E13, E14, E16, E18
	Normas e Integração de Ontologias	E1, E2, E7

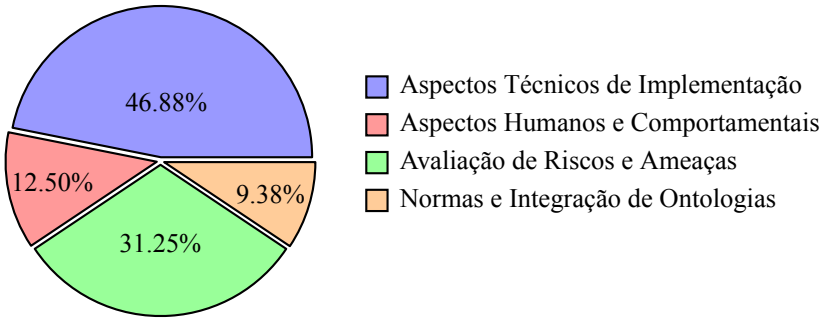


Figura 12: Distribuição percentual dos estudos nas dimensões de SI

Na **Figura 12**, é apresentada a distribuição percentual dos estudos pelas subcategorias identificadas nos estudos analisados.

4.5 Considerações Finais

Este RSL investigou o uso de ontologias de segurança em SI, destacando sua crescente relevância diante da integração progressiva de sistemas complexos, como Sistemas de Sistemas (SoS), Sistemas Ciberfísicos (CPS) e Sistemas Inteligentes. A revisão identificou 19 estudos publicados a partir de 2019, os quais exploram uma ampla gama de métodos, técnicas, modelos e ferramentas voltadas à segurança da informação com o uso de ontologias.

As ontologias demonstram um desempenho significativo na **unificação de dados heterogêneos**, na **redução de ambiguidades conceituais** e no **fortalecimento da governança da informação**. Sua aplicação se distribui em três dimensões fundamentais dos SI: **Pessoas**, **Processos** e **Tecnologias**.

Na dimensão das **Pessoas**, destacam-se abordagens que consideram fatores humanos e comportamentais, como a prevenção a ataques de engenharia social. No contexto dos **Processos**, sobressaem-se iniciativas voltadas à análise e avaliação de riscos, bem como à gestão de incidentes de segurança. Já na dimensão **Tecnológica**, observam-se avanços em frameworks, automação e integração com ferramentas e normas de segurança, promovendo a interoperabilidade e a capacidade de resposta a ameaças emergentes.

O RSL também evidencia uma diversidade de estratégias para a **avaliação das ontologias**, incluindo análises estruturais, testes práticos, métricas quantitativas e validações baseadas em critérios de qualidade e usabilidade. Essa avaliação é fundamental para assegurar o **desempenho** e a **adaptabilidade** das soluções em cenários reais. Um aspecto adicional de destaque é a **integração das ontologias com normas reconhecidas**, como as normas ISO, o que favorece a conformidade regulatória e a interoperabilidade com outros sistemas.

Como principal contribuição, propõe-se uma **taxonomia multidimensional**, apresentada no próximo capítulo desta monografia, estruturada segundo as três dimensões (**Pessoas**, **Processos** e **Tecnologias**) e suas respectivas subcategorias, com base nas questões de pesquisa analisadas neste RSL.

5. Taxonomia

Este capítulo está organizado da seguinte forma. A Seção 5.1 apresenta o objetivo da construção da taxonomia. A Seção 5.2 descreve as etapas do processo de construção da taxonomia. Por fim, a Seção 4.5 traz algumas considerações finais.

5.1 Introdução

A crescente integração de sistemas, impulsionada pelo uso das *APIs* (*Application Programming Interfaces*), evidenciou a necessidade de conectar diferentes tipos de sistemas complexos, como os *Sistemas de Sistemas* (SoS), *Sistemas Ciberfísicos* (CPS) e *Sistemas Inteligentes*. Essa integração requer colaboração entre diversas plataformas e serviços, ampliando significativamente a demanda por interoperabilidade nos Sistemas de Informação (SI).

Diante desse cenário, esta pesquisa teve como objetivo desenvolver uma **taxonomia multidimensional**, estruturada com base em três dimensões principais — **Pessoas**, **Processos** e **Tecnologias** — e suas respectivas subcategorias, conforme as questões de pesquisa analisadas no Capítulo 4. Para isso, adotou-se uma metodologia voltada ao desenvolvimento de taxonomias fundamentadas na pesquisa em SI, conforme proposta por (ARAUJO et al., 2017), utilizando a abordagem de modelagem adaptada por (BRASILEIRO et al., 2019b), com base no estudo de (CAMPOS; GOMES, 2008a).

5.2 Processo de contrução da taxonomia

Esta seção descreve o processo de construção da taxonomia proposta neste trabalho. A elaboração seguiu as diretrizes sugeridas por (BRASILEIRO et al., 2019b), baseadas no estudo de (CAMPOS; GOMES, 2008a), e foi conduzida conforme as etapas apresentadas

na Seção 2.3 do Capítulo 2.

5.2.1 Etapa 1 - Determinar o domínio e o escopo da taxonomia

Nesta etapa, foram definidos propósito, objetivos, público-alvo, tipo e escopo da taxonomia, organizados no template da Tabela 16.

Tabela 16: Template de Especificação da Taxonomia

Domínio/escopo geral
Esta taxonomia de domínio representa o conhecimento relacionado à segurança da informação em Sistemas de Informação (SI), com o objetivo de identificar ferramentas, métodos, modelos e técnicas utilizados, avaliar seu desempenho e mapear os componentes relevantes nas dimensões: Pessoas, Processos e Tecnologias.
Propósito geral
Esta taxonomia tem como objetivo apoiar técnicos, especialistas, gestores de TI e pesquisadores na gestão da segurança da informação em SI, por meio da explicitação de ferramentas, métodos, modelos e técnicas empregados, da avaliação de seu desempenho e do mapeamento de componentes nas dimensões Pessoas, Processos e Tecnologias. Busca, assim, subsidiar a mitigação de riscos, vulnerabilidades e ameaças nos SI organizacionais com base em uma compreensão técnica e aplicada.
Classes de usuários
Esta taxonomia destina-se a oferecer suporte a técnicos, especialistas, gestores de TI e pesquisadores na gestão da segurança da informação em SI.
Tipo de taxonomia
Esta taxonomia é caracterizada como uma taxonomia de domínio voltada para o controle da segurança da informação nos SI.
Delimitação do escopo de cobertura

Continua na próxima página.

Tabela 17 - Template de Especificação da Taxonomia. *Continuação.*

Ponto de Partida: A proposta de construção de uma taxonomia de domínio para representar a segurança da informação em SI surgiu da necessidade de tratar essa temática diante da intensificação da integração de uma multiplicidade de sistemas, impulsionada pelo uso extensivo de Interfaces de Programação de Aplicações (APIs). Esse contexto evidencia a crescente interoperação entre sistemas complexos, como Sistemas de Sistemas (Systems-of-Systems – SoS), Sistemas Ciberfísicos (Cyber-Physical Systems – CPS) e Sistemas Inteligentes (Intelligent Systems – IS). A taxonomia proposta visa, portanto, fornecer suporte estruturado a técnicos, especialistas, gestores de TI e pesquisadores no controle da segurança da informação em ambientes de SI.
Questões de competência
1. Quais ferramentas, métodos, modelos e técnicas são utilizadas no desenvolvimento de ontologias de segurança, considerando as dimensões Pessoas, Processos e Tecnologia em Sistemas de Informação (SI)? 2. Como é avaliado o desempenho das ontologias de segurança, considerando as dimensões Pessoas, Processos e Tecnologia em SI? 3. Quais componentes impactam o desenvolvimento e a aplicação das ontologias de segurança em cada uma das dimensões dos SI?

5.2.2 Etapa 2 - Definir o processo de aquisição de conhecimento para a construção da taxonomia

Os termos foram reunidos, definidos e enumerados com base nos resultados dos trabalhos relacionados apresentados no Capítulo 3 em conjunto com os elementos identificados da RSL do Capítulo 4.

5.2.3 Etapa 3 - Analisar e organizar o conhecimento para a contrução da taxonomia

A rastreabilidade dos estudos que fundamentam a taxonomia de ontologias voltadas à Segurança em SI foi realizada por meio da seleção e categorizaçãoDOS dos elementos identificados nas resposta às três subquestões da RSL, apresentadas no Capítulo 4. Tais subquestões, que também representam as questões de competência, foram estruturadas de acordo com as três dimensões dos SI: Pessoas, Processos e Tecnologia.

5.2.4 Etapa 4 - Estruturar e modelar a taxonomia

A hierarquia da taxonomia foi definida por meio de um processo de desenvolvimento *top-down*, resultando em uma estrutura multidimensional composta por três dimensões fundamentais da área de SI)e suas respectivas subcategorias. A construção dessa estrutura teve como base as questões de competência identificadas na RSL apresentada no Capítulo 4. A Figura 13 apresenta a taxonomia multidimensional estruturada de acordo com as três dimensões identificadas, em resposta às questões de competência formuladas na Etapa 1, seguindo o formato proposto por Sutter et al. (2024) (SUTTER et al., 2024).

Com base na análise sistemática dos estudos selecionados do no Capítulo 4, propõe-se uma taxonomia multidimensional organizada nas três dimensões fundamentais em SI:

5.2.4.1 Taxonomia elaborada a partir da análise sistemática dos estudos selecionados, com o objetivo de responder à Questão de Competência 1.

1. Dimensão: Pessoas

- **1.1. Aplicações práticas em contextos reais**
  - APKOWL para detecção de malware SMS em Android. (E15)
  - Ontologia de domínio para engenharia social e análise de ataques. (E8)
  - Ontologia para modelar riscos de privacidade em aeroportos inteligentes. (E18)
  - Sistema VALARIN para análise de PDFs maliciosos. (E17)
  - Uso da ontologia Rantology para segurança digital. (E5)

2. Dimensão: Processos

- **2.1. Análise e Avaliação de Riscos**
  - Análise conceitual de riscos com base na ISO 27005 e NIST 800-30 (E13).
  - Avaliação de riscos conforme ISO/IEC 27001 no contexto de SGSI (E1).
  - Avaliação de riscos de privacidade em aeroportos inteligentes (E18).
  - Avaliação de riscos para ataques APT com integração de requisitos (E11).
  - Avaliação e tratamento de riscos com base na ISO/IEC 27005 (E4).
  - Mensuração da confiabilidade de sistemas via análise de riscos (E2).
  - Ontologia CSO baseada no NIST SP 800-30 para modelar riscos (E10).
- **2.2. Modelagem de Ontologias**
  - APKOWL: construção automática de ontologia sobre malware (E15).
  - CSO modelada com UML, CommonKADS e Methontology (E10).
  - Estrutura multi-ontológica baseada em ISO/IEC 27032 e MITRE (E12).
  - Método semiautomático de design ontológico com coleta online (E9).

- Ontologia OWL para leitura semântica de arquivos PDF (E17).
- Ontologia para SGSI construída no Protégé, alinhada à ISO (E1).
- Ontologia Rantology em OWL voltada a chantagens digitais (E5).
- Ontologia sobre engenharia social, exportada para Neo4j (E8).

3. Dimensão: Tecnologias

- **3.1. Desenvolvimento de Frameworks**
  - APKOWL para construção automática a partir de apps móveis (E15).
  - Framework para caracterização e classificação de ontologias (E13).
  - Framework para SIEM baseado em ontologia dupla camada; ISO 27000, BFO, OWL (E1).
  - Frameworks D3FEND (contramedidas) e IoTSec (IoT industrial) (E5).
  - Geração automática de ontologias genéricas (E9).
  - sCuDO: classificação de ataques com Ontologia UFO (E7).
  - STRAM: métricas para segurança, confiança, resiliência e agilidade (E2).
  - Sistematização de frameworks para normas ISO/IEC 27000 (E4).
- **3.2. Ferramentas e Automação**
  - CRATELO em OWL e SWRL para raciocínio automatizado em Edge Computing (E13).
  - Gerador automático de estratégias de ataque via grafo de conhecimento (E16).
  - PLN e mineração para extração de conceitos; visualização com yEd; aplicada a falhas automotivas (E19).
  - Protégé 4 + CO-ODE para modelagem colaborativa (E12).
  - Protégé e yEd para visualização/manipulação de grafos (E10).
  - Protégé para construção ontológica alinhada à ISO (E1).
  - Regras SWRL + Jess para detecção automatizada de intenções maliciosas (E15).
  - VALARIN: análise automática de PDFs usando ontologias, parsers e intervenção humana (E17).
- **3.3. Padronização e Qualidade**
  - Framework para classificação de ontologias baseado nos princípios FAIR (E13).
  - Methontology e IDEF5 para criação estruturada de ontologias (E10).
  - Normas ISO/IEC 9126 e 25000 para avaliação da qualidade de software (E2).
  - Ontologia baseada nas normas ISO/IEC 27000 e ISO/IEC 27001 (E1).
  - Rantology para detecção de extorsões digitais com critérios de qualidade (E5).
  - Recomenda ontologias para normas ISO/IEC 27k (E4).
  - Uso de múltiplas ontologias para interoperabilidade ISO/IEC 27032 (E12).

5.2.4.2 Taxonomia elaborada a partir da análise sistemática dos estudos selecionados, com o objetivo de responder à Questão de Competência 2.

1. Dimensão: Pessoas

- **1.1. Avaliações práticas e testes de usabilidade**
  - Avaliação da ontologia de engenharia social em cenários reais. **(E8)**
  - Clareza e aplicabilidade da ontologia Rantology. **(E5)**
  - Testes de desempenho em cenários de ataques. **(E19)**
  - Validação da ontologia de tarefas e aprendizagem em segurança. **(E6)**

2. Dimensão: Processos

- **2.1. Análise ontológica e de desempenho**
  - Avaliação de grafos de conhecimento. **(E18)**
  - Avaliação de desempenho usando STRAM. **(E2)**
  - Modelagem de incidentes de segurança com *sCuDO*. **(E7)**
  - Modelagem de padrões de segurança (ISO/IEC 27001 e 27002). **(E1)**
- **2.2. Metodologias de avaliação**
  - Auditoria e conformidade com ISO/IEC 27001. **(E4)**
  - Framework para classificação de ontologias. **(E13)**
  - Refinamento contínuo de multi-ontologias. **(E12)**
  - Revisão sistemática sobre métricas de segurança. **(E8)**
  - Validação de ISTMOF em estudos de caso. **(E7)**

3. Dimensão: Tecnologias

- **3.1. Avaliação quantitativa com métricas**
  - Avaliação da ontologia Rantology com métricas de OntoQA. **(E5)**
  - Avaliação de grafos de conhecimento em segurança. **(E18)**
  - Métricas de desempenho no STRAM. **(E2)**
  - Avaliação da ontologia de engenharia social em ataques. **(E8)**
- **3.2. Validação baseada em qualidade e eficácia em segurança**
  - Análise de consistência e completude de ontologias. **(E12)**
  - Avaliação de ontologias em segurança da informação. **(E13)**
  - Validação da ontologia STRAM com normas ISO/IEC 27000. **(E2)**
  - Validação em contexto comercial, comparando abordagens. **(E15)**
  - Avaliação da ontologia conforme normas ISO/IEC 27001. **(E10)**

5.2.4.3 Taxonomia elaborada a partir da análise sistemática dos estudos selecionados, com o objetivo de responder à Questão de Competência 2.

1. Dimensão de Pessoas

- **1.1. Aspectos Humanos e Comportamentais**
  - Classificação de incidentes baseada em fatores humanos **(E7)**
  - Conscientização situacional **(E5, E7)**
  - Engenharia social e fatores psicológicos **(E8)**
  - Impacto do comportamento do usuário **(E2, E5, E7, E8)**
  - Modelagem de vulnerabilidades humanas **(E2, E5, E7, E8)**

2. Dimensão de Processos

- **2.1. Avaliação de Riscos e Ameaças**
  - Análise holística de vulnerabilidades **(E2, E3, E10, E11)**
  - Avaliação de qualidade de dados **(E19)**
  - Gestão do ciclo de vida de segurança **(E1, E13)**
  - Mapeamento de riscos e suas consequências **(E1-E3, E10, E11, E13, E15, E18, E19)**
  - Modelagem de ameaças (APT, ransomware) **(E11, E15)**
  - Processos de certificação e auditoria **(E1, E13)**

3. Dimensão de Tecnologias

- **3.1. Aspectos Técnicos de Implementação**
  - Ferramentas de desenvolvimento (Protégé, Neo4j) **(E1, E2, E4, E5, E8, E14)**
  - Frameworks ontológicos (STRAM, CSO, IJPRA) **(E2, E10, E18)**
  - Métodos formais de representação (OWL, RDF, SPARQL) **(E1-E10, E12-E14, E16, E18)**
  - Processamento automatizado e machine learning **(E5, E6, E9, E14)**
  - Técnicas de engenharia ontológica **(E3, E6, E9, E12)**

- **3.2. Normas e Integração de Ontologias**
  - Conformidade com normas reconhecidas (ISO/IEC 27000, NIST, PCI DSS) **(E1, E2, E7, E10, E13, E18)**
  - Integração com padrões e sistemas existentes **(E1, E2, E7, E10, E13, E18)**
  - Interoperabilidade semântica entre domínios **(E1, E2, E7, E10, E13, E18)**
  - Modelagem de múltiplas camadas (BFO, UFO, MLT) **(E1, E7, E10)**
  - Validação terminológica baseada em normas **(E13, E18)**

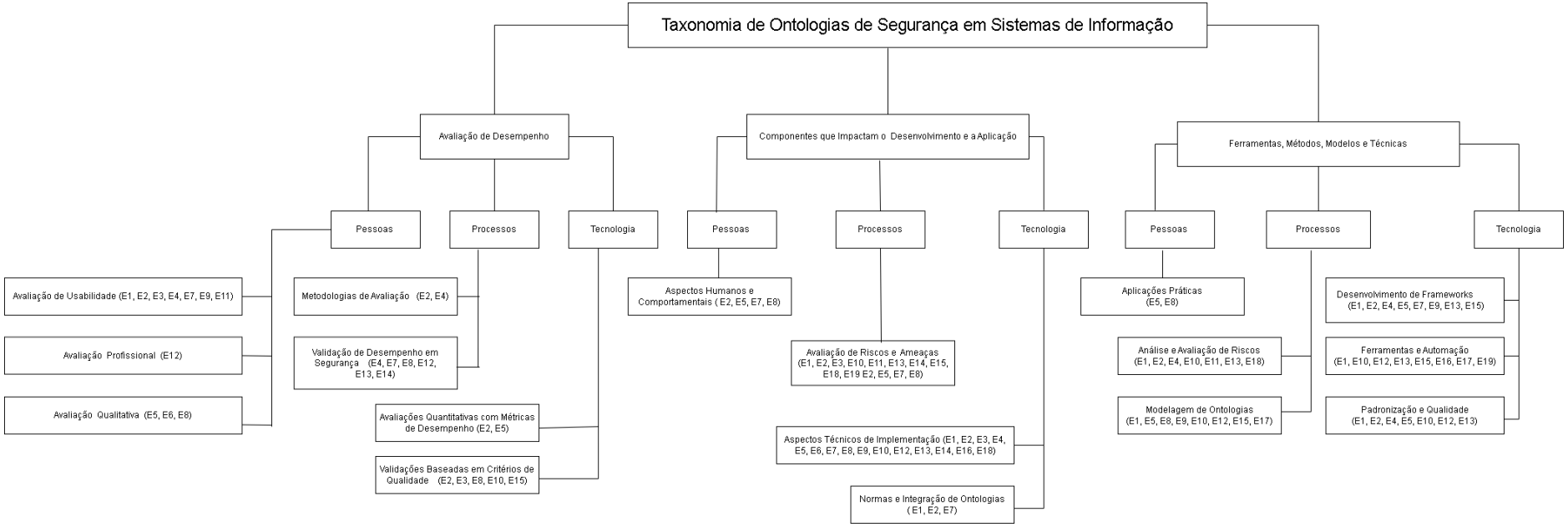


Figura 13: Taxonomia multidimensional organizada nas três dimensões de SI.

5.3 Considerações Finais

Este capítulo teve como objetivo definir e descrever as etapas de desenvolvimento da **taxonomia multidimensional**, estruturada a partir de três dimensões principais — **Pessoas**, **Processos** e **Tecnologias** — e suas respectivas subcategorias, com base nas questões de pesquisa analisadas nesta Revisão Sistemática da Literatura (RSL).

A análise das etapas demonstrou que o desenvolvimento de uma taxonomia não é uma tarefa trivial. Contudo, ao se empregar uma metodologia clara, de fácil aplicação e compreensão, o processo torna-se significativamente mais produtivo. Destaca-se, ainda, a relevância da participação de um especialista com *expertise* na área, fator essencial para garantir a qualidade e a efetividade na construção da taxonomia.

Como contribuição prática, a taxonomia proposta poderá ser utilizada por técnicos, gestores e especialistas de TI como um referencial estruturado, promovendo o consenso terminológico e a padronização da linguagem empregada em documentos, bem como na comunicação entre equipes e *stakeholders* envolvidos em questões relacionadas à segurança da informação em SI, seguindo o formato proposto por Sutter et al. (2024) (SUTTER et al., 2024).

6. Conclusão

Este capítulo apresenta as conclusões da monografia, destacando as principais contribuições da pesquisa e as suas limitações. Além disso, são discutidas possíveis direções para trabalhos futuros.

6.1 Epílogo

A intensificação da integração de sistemas, impulsionada pelo uso de *Interfaces de Programação de Aplicações* (APIs), tem evidenciado a crescente interoperação entre diferentes sistemas complexos, como os *Sistemas de Sistemas* (*Systems-of-Systems* – SoS), os *Sistemas Ciberfísicos* (*Cyber-Physical Systems* – CPS) e os *Sistemas Inteligentes* (*Intelligent Systems*) (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022).

Esses sistemas, categorizados como sistemas complexos em Sistemas de Informação (SI), têm como objetivo central a integração de tecnologias e conhecimentos heterogêneos, a fim de viabilizar autonomia, confiabilidade, organização e controle eficazes, minimizando ou eliminando a necessidade de intervenção humana direta (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018a; INOCêNCIO et al., 2019; LADEGOURDIE; KUA, 2022).

Em ambientes sociotécnicos — que combinam aspectos sociais e tecnológicos — e que apresentam elevada dinamicidade, os sistemas complexos distribuídos no contexto dos SI desempenham papel fundamental na prestação de serviços críticos em diversas áreas, tais como: controle de tráfego, distribuição de energia, gerenciamento de edificações, integração de modais de transporte, operação de veículos autônomos, saúde, segurança pública, vigilância, entre outros. (MAIER, 1998; RUSSELL; NORVIG, 2010; SOMMERVILLE, 2016b; GHAZANI et al., 2012; ZEADALLY; JABEUR, 2016; CAVALCANTE et al., 2016; AAZAM et al., 2018; ALGULIYEV et al., 2018b; Fernandes et al., 2019; LADEGOURDIE; KUA, 2022).

Nesse contexto, garantir a transparência e a interoperabilidade entre esses sistemas complexos

distribuídos representa um desafio significativo, uma vez que a interconectividade e a cooperação devem ser continuamente mantidas para o cumprimento dos objetivos estabelecidos (BERNARDINI et al., 2017; FERNANDES et al., 2018). Transparência e interoperabilidade permanecem premissas essenciais e complementares, embora sejam frequentemente dificultadas pelas distintas políticas de acesso e visibilidade adotadas por cada sistema. Assim, a integração eficiente de dados continua sendo um dos principais desafios contemporâneos na área de sistemas complexos distribuídos em SI.

Tais sistemas podem se interconectar com a computação em nuvem, especialmente para fins de armazenamento de dados, e com sistemas de *Big Data Analytics*, que permitem coletar, inspecionar, tratar e modelar grandes volumes de dados com o intuito de obter *insights* e identificar oportunidades organizacionais. *Big Data* e computação em nuvem tornaram-se recursos estratégicos relevantes, sobretudo em setores como o financeiro e o bancário. Muitas organizações acessam seus dados por meio de links em plataformas de nuvem, enquanto outras, de maior porte, optam pelo desenvolvimento de *data centers* com nuvens privadas ou híbridas. Além disso, sistemas *ERP* podem ser utilizados para integrar dados e processos de diversos departamentos organizacionais.

Essa integração possibilita que os *Sistemas de Sistemas* (SoS), os *Sistemas Ciberfísicos* (CPS) e os *Sistemas Inteligentes* interoperem entre si, compartilhem suas bases de dados e sejam aplicados em diferentes cenários, plantas e arquiteturas no contexto dos sistemas distribuídos em SI.

Entretanto, destaca-se o aumento contínuo no número e na gravidade dos ataques cibernéticos. A segurança cibernética tem se tornado uma preocupação central, uma vez que falhas nesse aspecto podem comprometer a integridade dos sistemas integrados e gerar impactos desastrosos à segurança operacional. Infraestruturas críticas, como as usinas nucleares — por exemplo, Angra 1, Angra 2 e, futuramente, Angra 3 — operadas pela Eletronuclear[1], estão particularmente vulneráveis a essas ameaças.

Dessa forma, a Questão Principal da Pesquisa (QPP) foi respondida por meio da elaboração de uma taxonomia voltada para apoiar técnicos, especialistas e gestores de TI na mitigação das dificuldades relacionadas à segurança em sistemas complexos operados em ambientes distribuídos dos SI. Nesse contexto, falhas podem ampliar significativamente a superfície de exposição a ameaças, bem como a gravidade dos impactos decorrentes de ataques cibernéticos.

Para isso, foi formulada uma questão de pesquisa (QP), acompanhada de três subquestões (SQ1, SQ2 e SQ3), que orientaram a condução da Revisão Sistemática da Literatura (RSL).

Em resposta à **SQ1**, a RSL permitiu identificar os seguintes tópicos recorrentes:

- Análise e avaliação de riscos,
- Aplicações práticas,

[1] <https://www.eletronuclear.gov.br/Nossas-Atividades/Paginas/default.aspx>

- Desenvolvimento de *frameworks*,
- Ferramentas e automação,
- Modelagem de ontologias,
- Padronização e qualidade.

Com relação à **SQ2**, foi possível observar abordagens voltadas para:

- Avaliação de usabilidade,
- Avaliação profissional,
- Avaliação qualitativa,
- Metodologias de avaliação,
- Validação do desempenho em segurança,
- Avaliações quantitativas com uso de métricas,
- Validações baseadas em critérios de qualidade.

Por fim, no âmbito da **SQ3**, foram identificados os seguintes aspectos:

- Aspectos técnicos de implementação,
- Aspectos humanos e comportamentais,
- Avaliação de riscos e ameaças,
- Normas e integração de ontologias.

6.2 Contribuições

Esta monografia contribui para:

1) Fundamentação da segurança da informação no contexto de sistemas complexos em ambientes distribuídos de SI, com a devida caracterização desse domínio e a construção de um corpo de conhecimento que sirva de apoio a pesquisadores e profissionais da área. Esse estudo visa subsidiar o planejamento e o desenvolvimento de soluções voltadas à segurança da informação nesses ambientes trazendo soluções nesta área.

2) Identificação do cenário de segurança da informação em sistemas complexos operando em ambientes distribuídos de SI, por meio do mapeamento de tópicos recorrentes, das principais abordagens e dos aspectos que influenciam a escolha dos mecanismos de segurança utilizados no controle desses sistemas.

6.3 Trabalhos Futuros

Este estudo poderá ser ampliado em trabalhos futuros por meio de uma investigação mais abrangente de questões de pesquisa adicionais, bem como pela continuidade e aprofundamento das etapas de desenvolvimento descritas no Capítulo 2, com ênfase na Seção 2.4.

Referências Bibliográficas

AAZAM, M.; ZEADALLY, S.; HARRAS, K. A. Deploying fog computing in industrial internet of things and industry 4.0. *IEEE Transactions on Industrial Informatics*, v. 14, p. 4674–4682, 2018. Disponível em: <https://api.semanticscholar.org/CorpusID:52932598>.

ABOSHADY, D. et al. Apkowl: An automatic approach to enhance the malware detection. *Mobile Networks and Applications*, p. 1–12, 2023. Disponível em: <https://api.semanticscholar.org/CorpusID:259965128>.

ADACH, M.; HäNNINEN, K.; LUNDQVIST, K. A combined security ontology based on the unified foundational ontology. In: *2022 IEEE 16th International Conference on Semantic Computing (ICSC)*. [S.l.: s.n.], 2022. p. 187–194.

AGANETTE, E.; ALVARENGA, L.; SOUZA, R. Definições e aplicações de taxonomia em organizações. *Revista de Gestão da Informação*, v. 5, p. 45–60, 2010.

ALABSI, M.; GILL, A.; BANDARA, M. Integrated interaction journey and privacy risk assessment: A graph model. *Procedia Computer Science*, v. 239, p. 1594–1603, 2024. ISSN 1877-0509. CENTERIS – International Conference on ENTERprise Information Systems / ProjMAN - International Conference on Project MANagement / HCist - International Conference on Health and Social Care Information Systems and Technologies 2023. Disponível em: <https://www.sciencedirect.com/science/article/pii/S1877050924015795>.

ALGULIYEV, R.; IMAMVERDIYEV, Y.; SUKHOSTAT, L. Cyber-physical systems and their security issues. *Computers in Industry*, v. 100, p. 212–223, 2018. ISSN 0166-3615. Disponível em: <https://www.sciencedirect.com/science/article/pii/S0166361517304244>.

ALGULIYEV, R.; IMAMVERDIYEV, Y.; SUKHOSTAT, L. Cyber-physical systems and their security issues. *Computers in Industry*, v. 100, p. 212–223, 2018. ISSN 0166-3615. Disponível em: <https://www.sciencedirect.com/science/article/pii/S0166361517304244>.

ARAUJO, R.; FORNAZIN, M.; PIMENTEL, M. Uma análise sobre a produção de conhecimento científico nas pesquisas publicadas nos primeiros 10 anos da isys (2008-2017). *isys-Revista Brasileira de Sistemas de Informação*, v. 10, p. 45–65, 12 2017.

BELANI, H. et al. Ontology-based cybersecurity for well-being, aging and health: A scoping review. In: *2023 IEEE International Mediterranean Conference on Communications and Networking (MeditCom)*. [S.l.: s.n.], 2023. p. 50–55.

BERNARDINI, F. C. et al. General features of smart city approaches from information systems perspective and its challenges. In: BOSCARIOLI, C.; ARAUJO, R. M.; MACIEL, R. S. P. (Ed.). *I GrandDSI-BR*. Porto Alegre: SBC-Sociedade Brasileira de Computação, 2017. cap. 3, p. 107–118.

BRASILEIRO, □. et al. *Guia do usuário do TemaTres*. [S.l.: s.n.], 2019. ISBN 9788570131553.

BRASILEIRO Ítalo et al. *Guia do usuário do TemaTres*. [S.l.: s.n.], 2019. ISBN 9788570131553.

CAMPOS, M. L.; GOMES, H. E. Taxonomia e classificação: o princípio de categorização. *DataGramaZero*, v. 9, n. 4, 2008.

CAMPOS, M. L. A.; GOMES, H. E. *Taxonomia Corporativa: Métodos e Práticas*. São Paulo: Editora ABC, 2008.

CASOLA, V.; CATELLI, R.; BENEDICTIS, A. D. A first step towards an iso-based information security domain ontology. In: *2019 IEEE 28th International Conference on Enabling Technologies: Infrastructure for Collaborative Enterprises (WETICE)*. [S.l.: s.n.], 2019. p. 334–339.

CAVALCANTE, E. et al. Thinking smart cities as systems-of-systems: A perspective study. In: *Proceedings of the 2nd International Workshop on Smart*. [S.l.: s.n.], 2016. p. 1–4.

CHO, J.-H. et al. Stram: Measuring the trustworthiness of computer-based systems. *ACM Comput. Surv.*, Association for Computing Machinery, New York, NY, USA, v. 51, n. 6, fev. 2019. ISSN 0360-0300. Disponível em: <https://doi.org/10.1145/3277666>.

DHILLON, G.; KOLKOWSKA, E. Can a cloud be really secure? a socratic dialogue. In: ____. *Computers, Privacy and Data Protection: an Element of Choice*. Dordrecht: Springer Netherlands, 2011. p. 345–360. ISBN 978-94-007-0641-5. Disponível em: <https://doi.org/10.1007/978-94-007-0641-5_16>.

Dyba, T.; Dingsoyr, T.; Hanssen, G. K. Applying systematic reviews to diverse study types: An experience report. In: *ESEM 2007*. [S.l.: s.n.], 2007. p. 225–234.

FARIA, M. R. et al. Applying multi-level theory to an information security incident domain ontology. In: *ONTOBRAS*. [s.n.], 2019. Disponível em: <https://api.semanticscholar.org/CorpusID:209430754>.

Fernandes, J. et al. A conceptual model for systems-of-information systems. In: *2019 IEEE 20th International Conference on Information Reuse and Integration for Data Science (IRI)*. [S.l.: s.n.], 2019. p. 364–371.

FERNANDES, J. C.; NETO, V. V. G.; SANTOS, R. P. Interoperability in systems-of-information systems: A systematic mapping study. In: *Proceedings of the SBQS 2018*. New York, NY, USA: Association for Computing Machinery, 2018. p. 131–140. ISBN 9781450365659. Disponível em: <https://doi.org/10.1145/3275245.3275259>.

GERGINOV, V. et al. Accuracy evaluation of primary frequency standard nist-f4. *Metrologia*, IOP Publishing, v. 62, n. 3, p. 035002, apr 2025. Disponível em: <https://doi.org/10.1088/1681-7575/adc7bd>.

GHAZANI, S. H. H. N.; LOTF, J. J.; ALIGULIYEV, R. A study on qos models for mobile ad-hoc networks. *International Journal of Modeling and Optimization*, IACSIT Press, v. 2, n. 5, p. 634, 2012.

HU, X. et al. Multiontology construction and application of threat model based on adversarial attack and defense under iso/iec 27032. *IEEE Access*, v. 10, p. 117955–117972, 2022.

INOCêNCIO, T. J. et al. Emergent behavior in system-of-systems: A systematic mapping study. In: *Proceedings of the XXXIII Brazilian Symposium on Software Engineering*. New York, NY, USA: Association for Computing Machinery, 2019. (SBES 2019), p. 140–149. ISBN 9781450376518. Disponível em: <https://doi.org/10.1145/3350768.3350779>.

ISO. *ISO/IEC 27002:2013 - Information technology — Security techniques — Code of practice for information security controls*. [S.l.], 2013.

JAY, J. Navigating paradox as a mechanism of a change and innovation in hybrid organizations. *The Academy of Management Journal*, v. 56, n. 1, p. 137–159, 2013.

KESHAVARZI, M.; GHAFFARY, H. R. An ontology-driven framework for knowledge representation of digital extortion attacks. *Computers in Human Behavior*, v. 139, p. 107520, 2023. ISSN 0747-5632. Disponível em: <https://www.sciencedirect.com/science/article/pii/S0747563222003405>.

KITCHENHAM, B.; CHARTERS, S. *Guidelines for performing Systematic Literature Reviews in Software Engineering*. [S.l.], 2007.

LADEGOURDIE, M.; KUA, J. Performance analysis of opc ua for industrial interoperability towards industry 4.0. *IoT*, 2022. Disponível em: <https://api.semanticscholar.org/CorpusID:254900364>.

LAM, D.; LI, L.; ANDERSON, C. Pdf investigation with parser differentials and ontology. *Trans. Info. For. Sec.*, IEEE Press, v. 19, p. 7774–7782, ago. 2024. ISSN 1556-6013. Disponível em: <https://doi.org/10.1109/TIFS.2024.3445733>.

LAUDON, K. C.; LAUDON, J. P. *Management Information Systems: Managing the Digital Firm*. 16th. ed. Harlow, England: Pearson, 2020.

LI, H. et al. Cybersecurity knowledge graphs construction and quality assessment. *Complex & Intelligent Systems*, v. 10, p. 1201–1217, 2023. Disponível em: <https://api.semanticscholar.org/CorpusID:261180126>.

LIN, W.; HAGA, R. Matching cyber security ontologies through genetic algorithm-based ontology alignment technique. *Security and Communication Networks*, Hindawi, v. 2021, 2021.

LIN, W.; HAGA, R. Matching cyber security ontologies through genetic algorithm-based ontology alignment technique. *Security and Communication Networks*, v. 2021, n. 1, p. 4856265, 2021. Disponível em: <https://onlinelibrary.wiley.com/doi/abs/10.1155/2021/4856265>.

MAIER, M. W. Architecting principles for systems-of-systems. *Systems Engineering*, v. 1, n. 4, p. 267–284, 1998.

MALAGUTTI, M. A. O. O papel da dissuasão no tocante a ofensas cibernéticas. *Doutrina Militar Terrestre em Revista*, v. 4, n. 9, p. 18–27, 2016.

MARTINS, B. F. et al. A framework for conceptual characterization of ontologies and its application in the cybersecurity domain. *Software and Systems Modeling*, v. 21, p. 1437 – 1464, 2022. Disponível em: <https://api.semanticscholar.org/CorpusID:250249932>.

MERIAH, I.; Arfa Rabai, L. B. Comparative study of ontologies based iso 27000 series security standards. *Procedia Computer Science*, v. 160, p. 85–92, 2019. ISSN 1877-0509. The 10th International Conference on Emerging Ubiquitous Systems and Pervasive Networks (EUSPN-2019) / The 9th International Conference on Current and Future Trends of Information and Communication Technologies in Healthcare (ICTH-2019) / Affiliated Workshops. Disponível em: <https://www.sciencedirect.com/science/article/pii/S187705091931662X>.

MERIAH, I.; RABAI, L. B. A.; KHEDRI, R. Towards an automatic approach to the design of a generic ontology for information security. In: *2021 Reconciling Data Analytics, Automation, Privacy, and Security: A Big Data Challenge (RDAAPS)*. [S.l.: s.n.], 2021. p. 1–8.

NETO, H. G. et al. Smart city architectures and the challenges for transparent interoperability. *International Journal of Distributed Systems and Technologies*, v. 8, n. 4, p. 37–52, 2017.

NIYAZOVA, R.; AKTAYEVA, A.; DAVLETKIREEVA, L. An ontology based model for user profile building using social network. In: *Proceedings of the 5th International Conference on Engineering and MIS*. New York, NY, USA: Association for Computing Machinery, 2019. (ICEMIS '19). ISBN 9781450372121. Disponível em: <https://doi.org/10.1145/3330431.3330453>.

NOY, N.; MCGUINNESS, D. Ontology development 101: A guide to creating your first ontology. *Knowledge Systems Laboratory*, v. 32, 01 2001.

OUEDRAOGO, W. F.; BIENNIER, F.; MERLE, P. Optimizing service protection with model driven security@ run. time. In: IEEE. *2015 IEEE Symposium on Service-Oriented System Engineering*. [S.l.], 2015. p. 50–58.

PARK, S.-H.; LEE, S.-W. Threat-driven risk assessment for apt attacks using risk-aware problem domain ontology. In: *2022 IEEE 30th International Requirements Engineering Conference Workshops (REW)*. [S.l.: s.n.], 2022. p. 226–231.

PIETZ, F. et al. Criptografia visual: método de alinhamento automático de parcelas utilizando dispositivos móveis. [sn], 2014.

ROGUSHINA, J. V. et al. Ontology-based approach to validation of learning outcomes for information security domain. In: *International Conference on Intelligent Tutoring Systems*. [s.n.], 2019. Disponível em: <https://api.semanticscholar.org/CorpusID:215807305>.

RUSSELL; NORVIG, S. Artificial intelligence: A modern approach. *Prentice Hall, Englewood Cliffs, NJ*, 01 2010.

SANTOS, F.; MELLO, C. E. Matching network of ontologies: A random walk and frequent itemsets approach. *IEEE Access*, v. 10, p. 44638–44659, 2022.

SIKOS, L. F. Cybersecurity knowledge graphs. *Knowledge and Information Systems*, v. 65, p. 3511–3531, 2023. Disponível em: <https://api.semanticscholar.org/CorpusID:258423071>.

SMITH, W.; LEWIS, M. Toward a Theory of Paradox: A Dynamic Equilibrium Model of Organizing. *Academy of Management Review*, v. 36, n. 2, p. 381–403, 2011.

SOMMERVILLE, I. *Software Engineering*. 10th. ed. Boston: Pearson, 2016.

SOMMERVILLE, I. *Software Engineering, 10th Edition*. [S.l.]: Pearson, 2016.

SUTTER, T. et al. Dynamic security analysis on android: A systematic literature review. *IEEE Access*, v. 12, p. 57261–57287, 2024.

SZYPERSKI, C. *Component Software: Beyond Object-Oriented Programming*. 2nd. ed. Boston: Addison-Wesley, 2002.

WANG, Z. et al. Social engineering in cybersecurity: a domain ontology and knowledge graph application examples. *Cybersecurity*, v. 4, 2021. Disponível em: <https://api.semanticscholar.org/CorpusID:235294079>.

WHITMAN, M. E.; MATTORD, H. J. *Principles of information security*. 3. ed. [S.l.]: Thompson Course Technology, 2009.

XUE, X.; TAN, W.; TIAN, Y. Matching cybersecurity ontologies on internet of everything through coevolutionary multiobjective evolutionary algorithm. *Sec. and Commun. Netw.*, John Wiley Sons, Inc., USA, v. 2022, jan 2022. ISSN 1939-0114. Disponível em: <https://doi.org/10.1155/2022/3572404>.

ZEADALLY, S.; JABEUR, N. *Cyber-physical system design with sensor networking technologies*. [S.l.]: Institution of Engineering and Technology, 2016.